

사이버보안 패러다임의 변화, 'N²SF와 제로 트러스트'

2025. 9. 26.

에스지에이솔루션즈(주) 대표이사/부회장 최영철
(ycchoi@sgacorp.kr)



최영철 대표이사/부회장 | 공학박사

☑ 과기정통부 제로 트러스트 2.0 가이드라인 집필진('24.7~12)

'24년 과기정통부 주관, 한국인터넷진흥원이 진행하는 제로 트러스트 2.0 가이드라인 작업에 가천대학교 이석준 교수와 함께 외부 집필진으로 포함되어 **2.0 가이드라인 제작에 참여함**

☑ 국가정보원 MLS(N²SF) TFT 참여위원('24.1~12)

'24년 1월부터 NIS가 추진하고 있는 망분리 개선사업 **MLS TFT 참여 위원으로 활동함**

☑ 한국 제로 트러스트 포럼 산업분과 위원('22.10~현재)

'22년 한국 제로 트러스트 포럼 산업분과 위원으로 과기정통부 '제로 트러스트 가이드라인 1.0' 제정에 참여하였으며, '23년도, '24년도 KISA 제로 트러스트 보안 모델 실증 사업을 성공적으로 수행하고 '25년 신한은행을 수요기업으로 금융부문 제로 트러스트 보안 모델 실증 사업 책임자로 사업 총괄 진행 중임

☑ 주요 업적

사업명	역할	주요내용	수행년도
국가망 보안체계 시범 실증 사업	주관	국가-공공기관 대상 국가망 보안체계 시범 실증사업	~ 2025.12.31
제로 트러스트 도입 시범사업	주관	2025년 제로 트러스트 도입 시범사업 (수요기관: 신한은행)	2025.05 ~ 2025.11
제로 트러스트 도입 시범사업	주관	제로 트러스트 도입 시범사업 (수요기관: 국가정보자원관리원)	2024.5 ~ 2024.12
정보보호핵심 원천기술개발	주관	언택트 시대의 기업망 보호를 위한 제로 트러스트 기반 접근제어 및 이상징후 분석기술 개발	2021.3 ~ 2024.12
제로 트러스트 보안 모델 실증 지원 사업	주관	제로 트러스트 보안 모델 실증 환경 구축 및 실증 수행	2023.6 ~ 2023.12

☑ 주요 경력

2012년 6월 ~ 현재	에스지에이솔루션즈(주)	대표이사/부회장
2024년 5월 ~ 현재	방산침해대응협의회	자문위원
2024년 4월 ~ 현재	KISA 클라우드 보안 협의체	의장
2024년 3월 ~ 현재	한국정보보호산업협회(KISIA)	부회장
2024년 3월 ~ 현재	국방혁신기술보안협회(KSAME)	부회장
2023년 3월 ~ 현재	한국디지털문서플랫폼협회	회장
2016년 1월 ~ 현재	한국정보보호학회	부회장
2010년 3월 ~ 2012년 5월	에스지에이(주)	부사장
2000년 6월 ~ 2010년 3월	(주)비씨큐어	대표이사
1998년 9월 ~ 2000년 3월	한국인터넷진흥원(KISA)	연구원

☑ 학력

1998년 ~ 2003년	성균관대학교 공학박사(정보보호)	전기전자컴퓨터공학부
1996년 ~ 1998년	성균관대학교 공학석사(정보보호)	전기전자컴퓨터공학부
1989년 ~ 1996년	성균관대학교 학사	정보공학과

I. 보안 컴플라이언스와 제로 트러스트 아키텍처

II. N²SF & ZTA Overlay

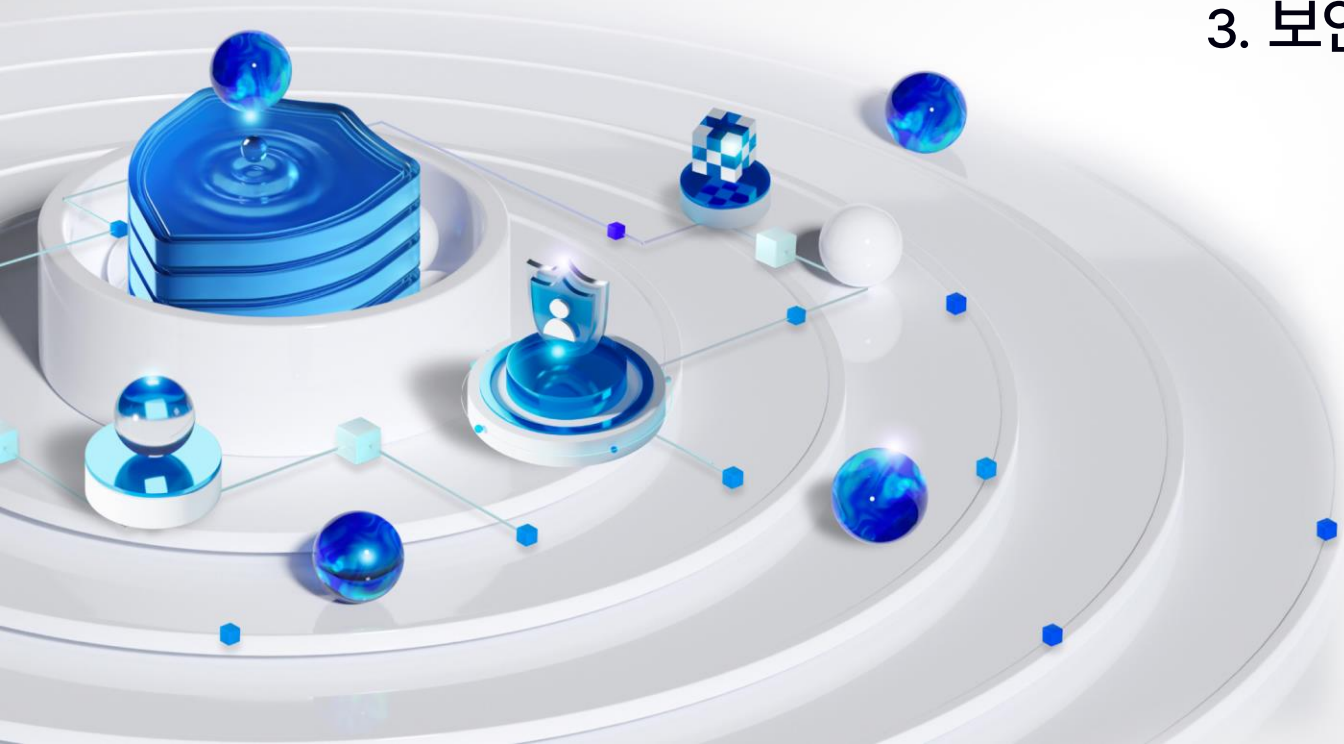
III. ISMS-P & ZTA Overlay

IV. SGA ZTA

I

보안 컴플라이언스와 제로 트러스트 아키텍처

1. 보안 컴플라이언스 제도
2. 제로 트러스트 아키텍처 2.0
3. 보안 컴플라이언스와 ZTA 오버레이



1. 보안 컴플라이언스 제도 (1/8) – NIST CSF 2.0

NIST CSF 2.0

- NIST 사이버 보안 프레임워크(NIST Cybersecurity Framework, CSF)는 조직이 사이버 보안 위험을 관리하고 개선하는 데 도움을 주기 위해 미국 국립표준기술연구소(NIST)에서 개발한 지침
- 주요 구성요소
 1. 핵심(Core): 사이버 보안 활동을 다섯 가지 기능으로 구분
 - **식별(Identify)**: 중요한 시스템과 자산을 이해하고 관리
 - **보호(Protect)**: 중요한 서비스의 제공을 보장하기 위해 적절한 보호 조치 구현
 - **탐지(Detect)**: 사이버 보안 이벤트를 신속하게 발견
 - **대응(Respond)**: 탐지된 사이버 보안 이벤트에 대응
 - **복구(Recover)**: 사이버 보안 이벤트로부터 복구하고 정상 운영을 복원
 2. 계층(Tiers): 조직의 사이버 보안 위험 관리 성숙도를 평가하는 데 사용
 - 총 4단계로 구성되어 있고, 각 단계는 조직의 위험 관리 접근 방식과 사이버 보안 활동의 통합 수준을 의미
 3. 프로파일(Profiles): 조직의 비즈니스 요구와 위험 관리 요구에 맞춘 맞춤형 사이버 보안 계획을 수립하는 데 사용
 - 프로파일은 현재 상태와 목표 상태를 비교하여 개선 계획을 수립하는 데 도움



1. 보안 컴플라이언스 제도 (2/8) – NIST CSF 2.0

CSF 2.0 기능 및 분류

Function	Category	Category Identifier
Govern (GV)	Organizational Context	GV.OC
	Risk Management Strategy	GV.RM
	Roles, Responsibilities, and Authorities	GV.RR
	Policy	GV.PO
	Oversight	GV.OV
	Cybersecurity Supply Chain Risk Management	GV.SC
Identify (ID)	Asset Management	ID.AM
	Risk Assessment	ID.RA
	Improvement	ID.IM
Protect (PR)	Identity Management, Authentication, and Access Control	PR.AA
	Awareness and Training	PR.AT
	Data Security	PR.DS
	Platform Security	PR.PS
	Technology Infrastructure Resilience	PR.IR
Detect (DE)	Continuous Monitoring	DE.CM
	Adverse Event Analysis	DE.AE
Respond (RS)	Incident Management	RS.MA
	Incident Analysis	RS.AN
	Incident Response Reporting and Communication	RS.CO
	Incident Mitigation	RS.MI
Recover (RC)	Incident Recovery Plan Execution	RC.RP
	Incident Recovery Communication	RC.CO

식별(Identify) 기능 예시

IDENTIFY (ID): The organization's current cybersecurity risks are understood

- **Asset Management (ID.AM):** Assets (e.g., data, hardware, software, systems, facilities, services, people) that enable the organization to achieve business purposes are identified and managed consistent with their relative importance to organizational objectives and the organization's risk strategy
 - **ID.AM-01:** Inventories of hardware managed by the organization are maintained
 - **ID.AM-02:** Inventories of software, services, and systems managed by the organization are maintained
 - **ID.AM-03:** Representations of the organization's authorized network communication and internal and external network data flows are maintained
 - **ID.AM-04:** Inventories of services provided by suppliers are maintained
 - **ID.AM-05:** Assets are prioritized based on classification, criticality, resources, and impact on the mission
 - **ID.AM-07:** Inventories of data and corresponding metadata for designated data types are maintained
 - **ID.AM-08:** Systems, hardware, software, services, and data are managed throughout their life cycles

NIST SP 800-53 r5

- NIST SP 800-53은 정보 시스템과 조직을 보호하기 위한 보안 및 프라이버시 통제 목록을 제공하는 정보 보안 표준
- 미국 연방 정부의 정보 시스템을 보호하기 위해 처음 개발되었지만, 현재는 일반적인 사용을 위해 개정

• 주요 내용

- 보안 통제 카탈로그: 정보 시스템과 조직을 다양한 위협과 위험으로부터 보호하기 위한 보안 및 프라이버시 통제 목록을 제공
- 통제 패밀리: 보안 통제는 기능에 따라 20개의 패밀리로 분류
(예: 접근 통제 (Access Control), 감사 및 책임(Audit and Accountability 등))
- 위험 관리 프레임워크: 조직이 위험을 관리하고 보안 통제를 구현하는 방법
- 유연성과 맞춤화: 다양한 조직의 요구에 맞게 보안 통제를 유연하게 적용할 수 있도록 설계

NIST Special Publication 800-53
Revision 5

Security and Privacy Controls for Information Systems and Organizations

JOINT TASK FORCE

This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-53r5>

September 2020
INCLUDES UPDATES AS OF 12-10-2020; SEE PAGE XVII



U.S. Department of Commerce
Wilbur L. Ross, Jr., Secretary

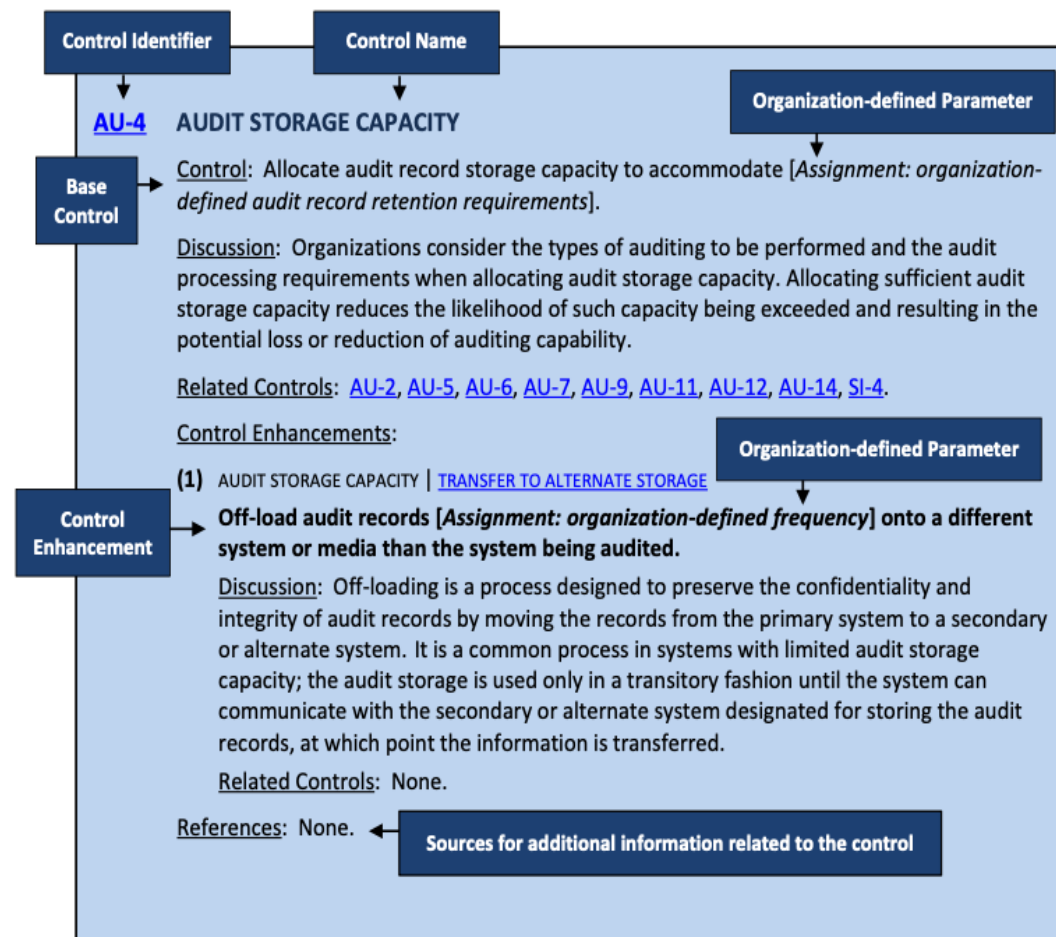
National Institute of Standards and Technology
Walter Copan, NIST Director and Under Secretary of Commerce for Standards and Technology

1. 보안 컴플라이언스 제도 (4/8) – NIST SP 800-53

보안 및 프라이버시 통제 패밀리 (20개)

ID	FAMILY	ID	FAMILY
AC	Access Control	PE	Physical and Environmental Protection
AT	Awareness and Training	PL	Planning
AU	Audit and Accountability	PM	Program Management
CA	Assessment, Authorization, and Monitoring	PS	Personnel Security
CM	Configuration Management	PT	PII Processing and Transparency
CP	Contingency Planning	RA	Risk Assessment
IA	Identification and Authentication	SA	System and Services Acquisition
IR	Incident Response	SC	System and Communications Protection
MA	Maintenance	SI	System and Information Integrity
MP	Media Protection	SR	Supply Chain Risk Management

보안 및 프라이버시 통제 패밀리 (20개)



1. 보안 컴플라이언스 제도 (5/8) – NIST SP 800-53

접근통제(AC) 패밀리 통제항목 예시

TABLE C-1: ACCESS CONTROL FAMILY

CONTROL NUMBER	CONTROL NAME CONTROL ENHANCEMENT NAME	IMPLEMENTED BY	ASSURANCE
AC-1	Policy and Procedures	O	√
AC-2	Account Management	O	
AC-2(1)	AUTOMATED SYSTEM ACCOUNT MANAGEMENT	O	
AC-2(2)	AUTOMATED TEMPORARY AND EMERGENCY ACCOUNT MANAGEMENT	S	
AC-2(3)	DISABLE ACCOUNTS	S	
AC-2(4)	AUTOMATED AUDIT ACTIONS	S	
AC-2(5)	INACTIVITY LOGOUT	O/S	
AC-2(6)	DYNAMIC PRIVILEGE MANAGEMENT	S	
AC-2(7)	PRIVILEGED USER ACCOUNTS	O	
AC-2(8)	DYNAMIC ACCOUNT MANAGEMENT	S	
AC-2(9)	RESTRICTIONS ON USE OF SHARED AND GROUP ACCOUNTS	O	
AC-2(10)	SHARED AND GROUP ACCOUNT CREDENTIAL CHANGE	W: Incorporated into AC-2k.	
AC-2(11)	USAGE CONDITIONS	S	
AC-2(12)	ACCOUNT MONITORING FOR ATYPICAL USAGE	O/S	
AC-2(13)	DISABLE ACCOUNTS FOR HIGH-RISK INDIVIDUALS	O	
AC-3	Access Enforcement	S	
AC-3(1)	RESTRICTED ACCESS TO PRIVILEGED FUNCTIONS	W: Incorporated into AC-6.	
AC-3(2)	DUAL AUTHORIZATION	S	
AC-3(3)	MANDATORY ACCESS CONTROL	S	
AC-3(4)	DISCRETIONARY ACCESS CONTROL	S	
AC-3(5)	SECURITY-RELEVANT INFORMATION	S	
AC-3(6)	PROTECTION OF USER AND SYSTEM INFORMATION	W: Incorporated into MP-4 and SC-28.	
AC-3(7)	ROLE-BASED ACCESS CONTROL	O/S	
AC-3(8)	REVOCATION OF ACCESS AUTHORIZATIONS	O/S	
AC-3(9)	CONTROLLED RELEASE	O/S	
AC-3(10)	AUDITED OVERRIDE OF ACCESS CONTROL MECHANISMS	O	
AC-3(11)	RESTRICT ACCESS TO SPECIFIC INFORMATION TYPES	S	
AC-3(12)	ASSERT AND ENFORCE APPLICATION ACCESS	S	
AC-3(13)	ATTRIBUTE-BASED ACCESS CONTROL	S	
AC-3(14)	INDIVIDUAL ACCESS	S	
AC-3(15)	DISCRETIONARY AND MANDATORY ACCESS CONTROL	S	
AC-4	Information Flow Enforcement	S	
AC-4(1)	OBJECT SECURITY AND PRIVACY ATTRIBUTES	S	
AC-4(2)	PROCESSING DOMAINS	S	
AC-4(3)	DYNAMIC INFORMATION FLOW CONTROL	S	
AC-4(4)	FLOW CONTROL OF ENCRYPTED INFORMATION	S	
AC-4(5)	EMBEDDED DATA TYPES	S	
AC-4(6)	METADATA	S	
AC-4(7)	ONE-WAY FLOW MECHANISMS	S	
AC-4(8)	SECURITY AND PRIVACY POLICY FILTERS	S	
AC-4(9)	HUMAN REVIEWS	O/S	
AC-4(10)	ENABLE AND DISABLE SECURITY OR PRIVACY POLICY FILTERS	S	

접근통제(AC) 패밀리 통제항목 세부내용 예시

NIST SP 800-53, REV. 5

SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

3.1 ACCESS CONTROL

[Quick link to Access Control Summary Table](#)

AC-1 POLICY AND PROCEDURES

Control:

- a. Develop, document, and disseminate to [Assignment: organization-defined personnel or roles]:
 1. [Selection (one or more): Organization-level; Mission/business process-level; System-level] access control policy that:
 - (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and
 - (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and
 2. Procedures to facilitate the implementation of the access control policy and the associated access controls;
- b. Designate an [Assignment: organization-defined official] to manage the development, documentation, and dissemination of the access control policy and procedures; and
- c. Review and update the current access control:
 1. Policy [Assignment: organization-defined frequency] and following [Assignment: organization-defined events]; and
 2. Procedures [Assignment: organization-defined frequency] and following [Assignment: organization-defined events].

Discussion: Access control policy and procedures address the controls in the AC family that are implemented within systems and organizations. The risk management strategy is an important factor in establishing such policies and procedures. Policies and procedures contribute to security and privacy assurance. Therefore, it is important that security and privacy programs collaborate on the development of access control policy and procedures. Security and privacy program policies and procedures at the organization level are preferable, in general, and may obviate the need for mission- or system-specific policies and procedures. The policy can be included as part of the general security and privacy policy or be represented by multiple policies reflecting the complex nature of organizations. Procedures can be established for security and privacy programs, for mission or business processes, and for systems, if needed. Procedures describe how the policies or controls are implemented and can be directed at the individual or role that is the object of the procedure. Procedures can be documented in system security and privacy plans or in one or more separate documents. Events that may precipitate an update to access control policy and procedures include assessment or audit findings, security incidents or breaches, or changes in laws, executive orders, directives, regulations, policies, standards, and guidelines. Simply restating controls does not constitute an organizational policy or procedure.

Related Controls: [IA-1](#), [PM-9](#), [PM-24](#), [PS-8](#), [SI-12](#).

Control Enhancements: None.

References: [\[OMB A-130\]](#), [\[SP 800-12\]](#), [\[SP 800-30\]](#), [\[SP 800-39\]](#), [\[SP 800-100\]](#), [\[IR 7874\]](#).

This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53-5>

CHAPTER THREE

PAGE 18

미국 우주 사이버 보안 예시 - NIST IR 8270

- 미국 국립표준기술연구소(NIST)가 2021년에 발간한 보고서로, 상업용 위성 운영을 위한 사이버 보안 지침을 제공
- 위성 산업이 민간 중심으로 확대되고 위성 기반 서비스(통신, 위치 정보, 기상 관측 등)의 중요성이 커지면서, 관련 보안 리스크를 체계적으로 다루기 위한 목적으로 작성

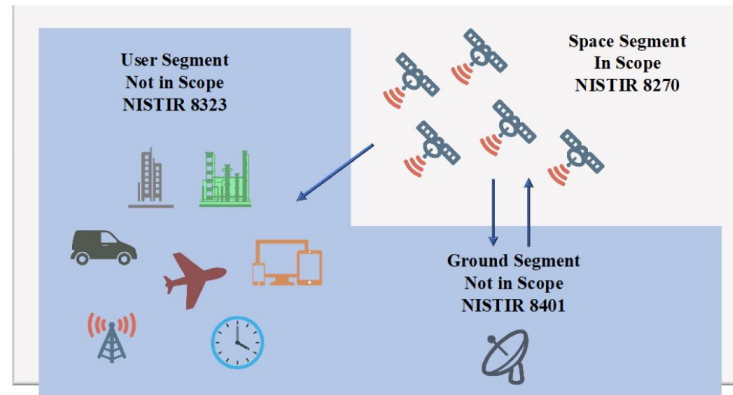
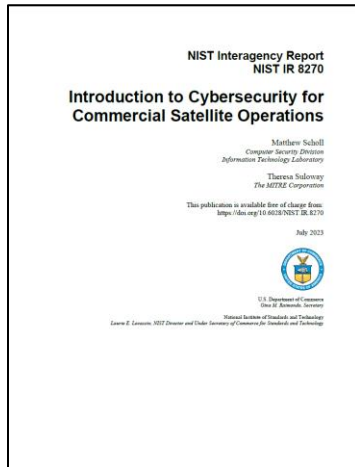


Fig. 1. Major parts of the conceptual high-level architecture of space operations

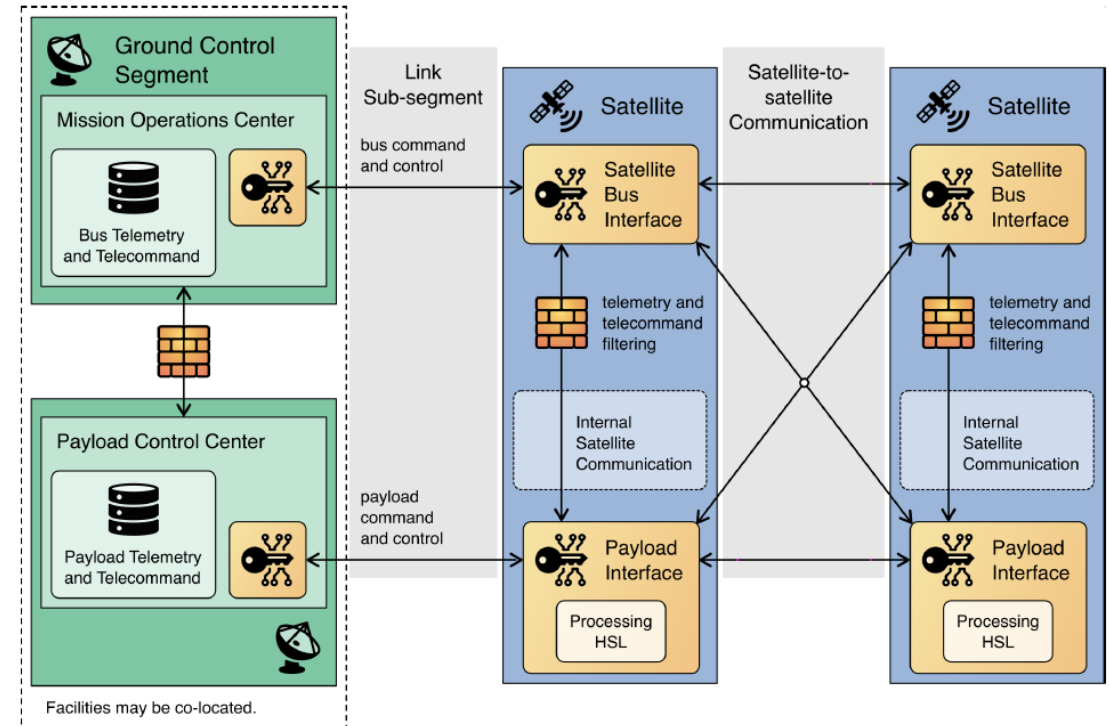


Fig. 2. Major communication links used in space systems

CSF를 활용한 사이버보안 요구사항 도출 및 NIST SP 800-53을 통한 통제항목 적용 예시

- 위성의 감지(sensing), 정보 처리(information processing), 데이터 획득(data acquisition), 통신(communications) 단계에서 CSF를 활용하여 사이버보안 요구사항 도출



Functions	Categories	Subcategories	Informative References
IDENTIFY			
PROTECT			
DETECT			
RESPOND			
RECOVER			



- 식별된 위협을 CSF 하위 범주(subcategories)와 매핑
- 부속 참고 자료(informative references)를 통해 CSF 하위 범주와 NIST SP 800-53 통제항목 매핑

Functions	Subcategories	1 Intentional jamming and spoofing of sensor data	2 Interception and theft of sensor data	3 Intentional corruption of sensor systems	4 Denial-of-service attack on sensor	5 Intentional jamming and spoofing of guidance control	6 Hijacking and unauthorized commands to guidance control	7 Malicious code injection	8 Denial-of-service attack on guidance
Recover	RC.RP-1								
	RC.IM-1								
	RC.IM-2								
	RC.CO-1								

Functions	Subcategories	Informative Reference	
		SP 800-53, Rev. 4	SP 800-53, Rev. 5
Recover	RC.RP-1: The recovery plan is executed during or after a cybersecurity incident.	CP-10, IR-4, IR-8	CP-10, IR-4, IR-8,
	RC.IM-2: Recovery strategies are updated.	CP-2, IR-4, IR-8	CP-2, IR-4, IR-8

1. 보안 컴플라이언스 제도 (8/8) – NIST IR 8270

NIST IR 시리즈의 CSF, NIST SP 800-53을 활용한 사이버보안 요구사항 도출 예시

Identify: Governance Category		
The policies, procedures, and processes to manage and monitor the organization's regulatory, legal, risk, environmental, and operational requirements are documented, reviewed, and inform the management of cybersecurity risk.		
ID.GV-1: Organizational cybersecurity policy is established and communicated	This subcategory enables the organization to identify key functions and assign areas of responsibility to ensure a comprehensive cybersecurity approach.	[NIST-SP800-53r5] AC-1, AT-1, AU-1, CA-1, CM-1, CP-1, IA-1, IR-1, MA-1, MP-1, PE-1, PL-1, PM-1, PS-1, PT-1, RA-1, SA-1, SC-1, SI-1, SR-1
ID.GV-2: Cybersecurity roles and responsibilities are coordinated and aligned with internal roles and external partners	Organizations should define roles and responsibilities between the organization and any third party such as cloud-based infrastructures or other services. These agreements are typically made in advance. Clearly defined internal roles and responsibilities will facilitate a response in a time of duress. If the PCC is operated by an external partner, then coordination of the roles and responsibilities between the mission owner and partner operations should be determined in	[NIST-SP800-53r5] PM-1, PM-2, PM-29, PS-7, PS-9 [NOAA-SW]

NIST IR 8401(Satellite Ground Segment)

Subcategory	Applicability to HSNs	Informative References
PR.AC-1: Identities and credentials are issued, managed, verified, revoked, and audited for authorized devices, users, and processes.	Emphasize managing credentials of devices, users, and processes identified by external organizations.	NIST SP 800-63-3 NIST SP 800-207 NIST SP 800-53 Rev. 5 IA-1, IA-2, IA-3, IA-4, IA-5, IA-6, IA-7, IA-8, IA-9, IA-10, IA-11, IA-12
PR.AC-2: Physical access to assets is managed and protected.	Emphasize managing physical access to assets by external organizations.	NISTIR 8320 NIST SP 800-53 Rev. 5 PE-1, PE-2, PE-3, PE-4, PE-5, PE-6, PE-8, PE-9
PR.AC-3: Remote access is managed.	Critical for HSNs. In addition to remote access for normal operations, consider access to external operators, users, and other personnel. Consider implementation of agile remote access procedures that are in accordance with the agreements between partners' and the organization's contingency plans.	NIST SP 800-53 Rev. 5 AC-1, AC-17, AC-19, AC-20, SC-15

NIST IR 8441(Cybersecurity Framework Profile for HSN)

Functions	Subcategories	Informative Reference	
		SP 800-53, Rev. 4	SP 800-53, Rev. 5
	ID.SC-4: Suppliers and third-party partners are routinely assessed using audits, test results, or other forms of evaluation to confirm that they are meeting their contractual obligations.	AU-6, PS-7, SA-9	AU-6, CA-2, CA-7, PS-7, SA-9, SA-11
Protect	PR.AC-1: Identities and credentials are issued, managed, verified, revoked, and audited for authorized devices, users, and processes.	IA-8	IA-8

NIST IR 8270 Satellite Operations (Introduction to Cybersecurity for Commercial)

Identify	Applicability to PNT	References (PNT-Specific)
Business Environment		
Subcategory		
BE-1: The organization's role in the supply chain is identified and communicated.	Organizations that engage in the reception and rebroadcast of PNT (or otherwise supply PNT) services to their consumers need to understand the cascading effects of a disruption or manipulation of PNT services to customers that may be a part of the critical infrastructure relying on the PNT service.	DHS S&T 2022 ISO 27001 NIST SP 800-37 NIST SP 800-53 Rev. 5 CP-2, SR-3, SR-4
BE-2: The organization's place in critical infrastructure and its industry sector is identified and communicated.	Critical infrastructure owner/operators need to understand and communicate the effects of a disruption or manipulation of PNT services on the organization's ability to fulfill its mission, objectives, or other stakeholders' needs. Distribution of PNT data may rely on critical infrastructures such as power and communications sectors. For example, the accuracy of time and frequency transfer over fiber are sensitive to reflections, and users can benefit from fiber maintenance techniques that minimize reflections.	DHS S&T 2022 NIST SP 800-53 Rev. 5 PM-11, RA-9 NIST TN 2187 IIA.1

NIST IR 8323(Foundational PNT Profile)

ZTA(Zero Trust Access)

- 사용자 및 디바이스 접근에 대한 보안에 중점을 둔 모델
- 기업자원 범주인 시스템, 데이터, 애플리케이션을 보호하기 위한 제로 트러스트 구성에 초점
- 디바이스 인증, 사용자 위험도 평가, 중앙 집중식 접근제어, 동적 접근정책 동작 등 주요 ZTA 기술요소가 모두 포함된 구조

ZTNA(Zero Trust Network Access)

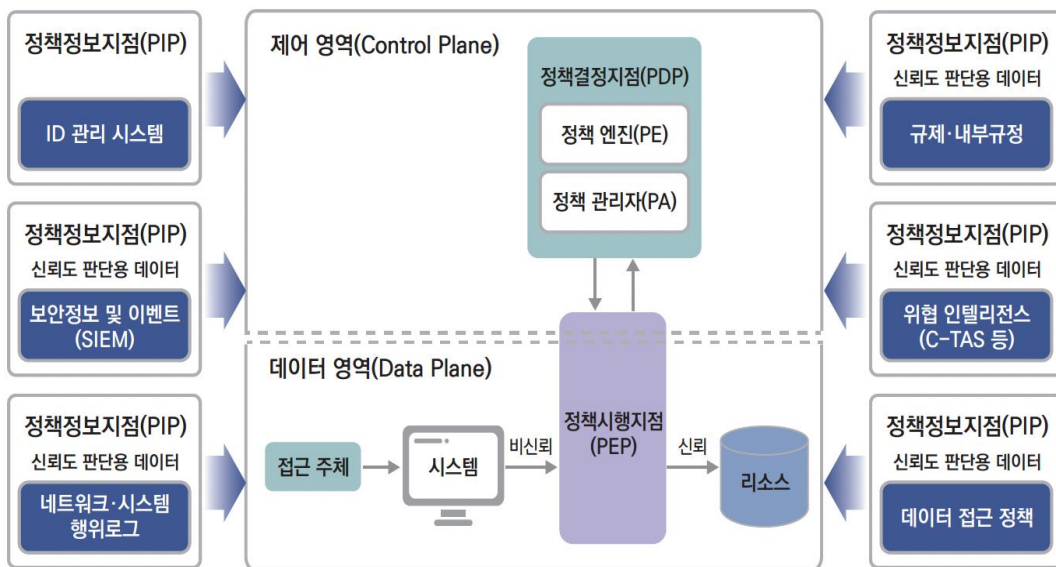
- 네트워크 기반의 제로 트러스트
- VPN, SSL-VPN 등을 네트워크 보안 관점에서 접근통제 가능한 네트워크 게이트웨이를 통해 연결
- 기업자원 범주인 시스템, 데이터, 애플리케이션 중 애플리케이션 보호와 안전한 네트워크 채널 구성에 초점

ZTA
Zero Trust
Architecture

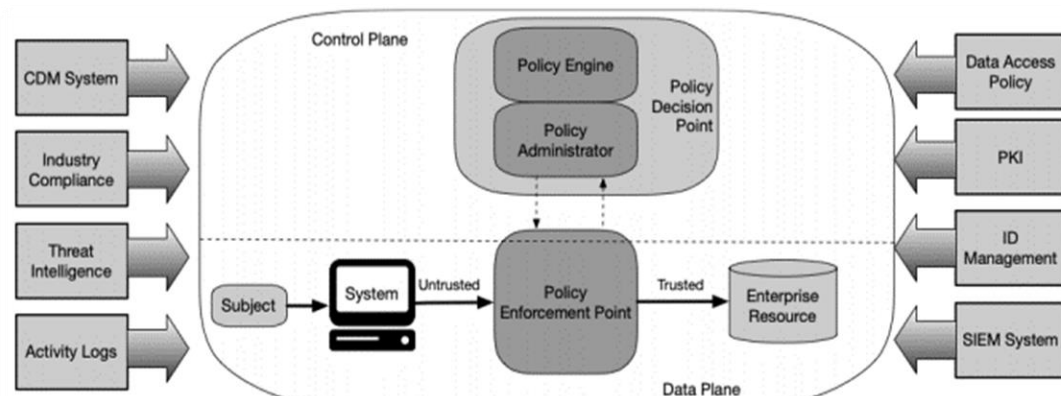
기존 IT 시스템에 제로 트러스트 보안을 적용하고 구축한다는 것은
종합적이고 완전한 'Zero Trust Architecture' 시스템을 구현하는 것임

2. 제로 트러스트 아키텍처 2.0 (2/6)

과학기술정보통신부/KISA 제로 트러스트 가이드라인 2.0 제로 트러스트 아키텍처 보안 모델



NIST(미국국립표준기술연구소) SP 800-207 Zero Trust Architecture



PE(정책 엔진)

- 주체(Subject, System 등)의 엔터프라이즈 리소스 접근 여부를 최종 결정
- 엔터프라이즈 정책 뿐만 아니라 외부 데이터 소스 입력을 신뢰 알고리즘을 기반으로 접근권한을 결정하고 기록

PA(정책 관리자)

- PEP와 통신하여 주체와 리소스 사이의 통신 경로를 설정하거나 폐쇄
- 접근여부 결정은 PE에 따르며 결정 실행
- 세션별 인증/인가 토큰, 크리덴셜을 생성하고 클라이언트는 이를 통해 리소스에 접근

PEP(정책시행지점)

- 주체와 엔터프라이즈 리소스 간 연결/모니터링/종료
- 사용자가 엔터프라이즈 리소스에 접근하는 데 사용하는 인증정보, 키 또는 토큰을 통해 세션 관리

PIP(정책정보지점)

- 정책 규칙으로 활용할 수 있는 정보를 생성 전달하는 논리 구성 요소
- 규제/내부규정, SIEM 정보, 데이터 접근 정책 등을 포함

접근 주체(Subject),시스템

- 주체는 사람과 NPE(Non-Person Entity)를 모두 포함
- 시스템은 하드웨어 컴포넌트(노트북, 핸드폰 등) 및 디지털 아티팩트(계정, 앱 등), 기업 소유이거나 아닌 시스템을 포함

외부 데이터 소스

- PE 입력 또는 정책 규칙으로 사용하는 등 접근을 결정하는데 도움이 될 수 있는 정보
- 기업 자산 상태, 규제, 로그, 위협, 속성, 인증, 계정, 피드백 등의 정보를 포함

2. 제로 트러스트 아키텍처 2.0 (3/6)

≡ 제로 트러스트 성숙도 진단

- 성숙도 단계는 제로 트러스트 도입계획 단계에서 현재 보안수준에 대한 평가 및 목표 수립, 예산 검토, 구현·운영 단계 등에서 완성도를 가늠할 수 있는 기준
- 과기정통부 제로 트러스트 가이드라인 2.0에서는 4단계로 구분하고 있으며, 6개 기업망 핵심요소 및 교차기능에 대해 그 수준을 진단함

≡ 성숙도 단계

핵심요소	설명
Traditional (기준)	• 아직 제로 트러스트 아키텍처를 적용하지 않은 수준으로, 대체로 네트워크 방어에 초점을 맞춘 경계 기반 보안모델이 적용되어 있는 상태(정교한 공격, 내부자 공격 등에 일부 취약성을 가짐) • 정적, 경계 기반, 수동 수준
Initial (초기)	• 조직이 제로 트러스트의 필요성을 인식하고 관련된 인프라, 정책을 개발/실행하기 위한 초기 단계 • 일부 자동화 수준
Advanced (향상)	• 제로 트러스트 철학을 부분적으로 도입한 수준으로 제로 트러스트 원칙이 보안 아키텍처에서 핵심 기능이 되는 상태(최소 권한 접근, 네트워크 분할, 로깅 및 모니터링 등이 부분적으로 적용되어 기본보다 높은 보안성 달성) • 자동화, 중앙집중적, 통합 수준
Optimal (최적화)	• 제로 트러스트 철학이 전사적으로 적용된 상태(자동화된 운영, 네트워크 세분화, 신원에 대한 지속적인 검증을 통한 최소 권한의 안전한 접근제어 등을 통하여 보안성이 크게 개선) • 동적, 완전 자동화 수준

≡ 핵심요소 및 교차기능

핵심요소	설명
식별자·신원	사람, 서비스, IoT 기기 등을 고유하게 설명할 수 있는 속성(속성의 집합)
기기 및 엔드포인트	IoT 기기, 휴대폰, 노트북, PC, 서버 등을 포함하여 네트워크에 연결해 데이터를 주고 받는 모든 하드웨어 장치
네트워크	기업망의 유선 네트워크, 무선 네트워크, 클라우드 접속을 포함하는 인터넷 등 데이터를 전송하기 위해 사용되는 모든 형태의 통신 매체
시스템	중요 응용 프로그램을 구동하거나 중요 데이터를 저장하고 관리하는 서버
응용 및 워크로드	기업망 관리 시스템, 프로그램, 온프레미스 및 클라우드 환경에서 실행되는 서비스
데이터	기업(기관)에서 가장 최우선적으로 보호해야 할 자원
교차기능	설명
가시성 및 분석	핵심요소들의 상태 확인 등 상황 정보를 분석할 수 있도록 가시성 제공
자동화 및 통합	자동화된 정책 기반 보안 프로세스 제공 및 SIEM 등 보안 솔루션 통합 기능

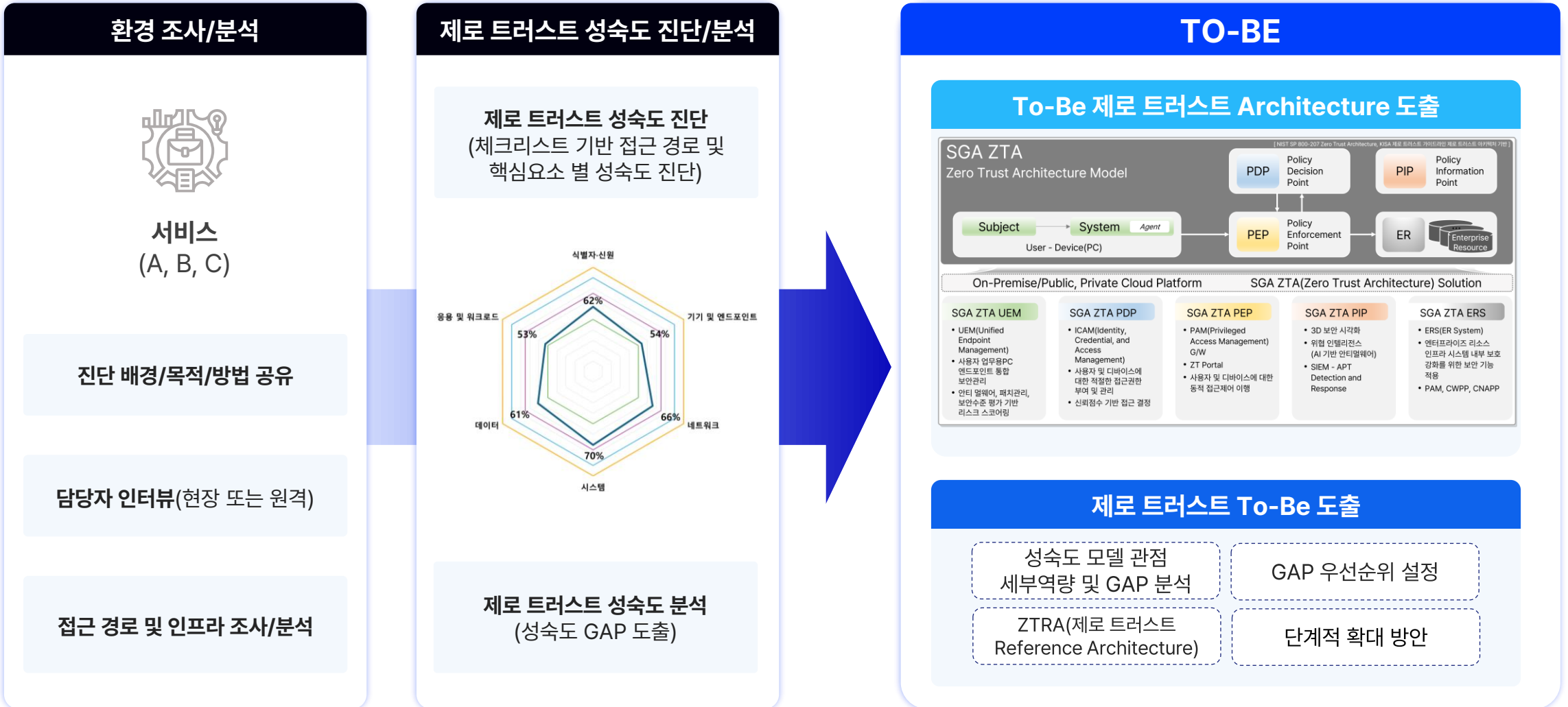
2. 제로 트러스트 아키텍처 2.0 (4/6)

≡ 제로 트러스트 성숙도 모델 2.0 핵심요소, 기능, 세부역량



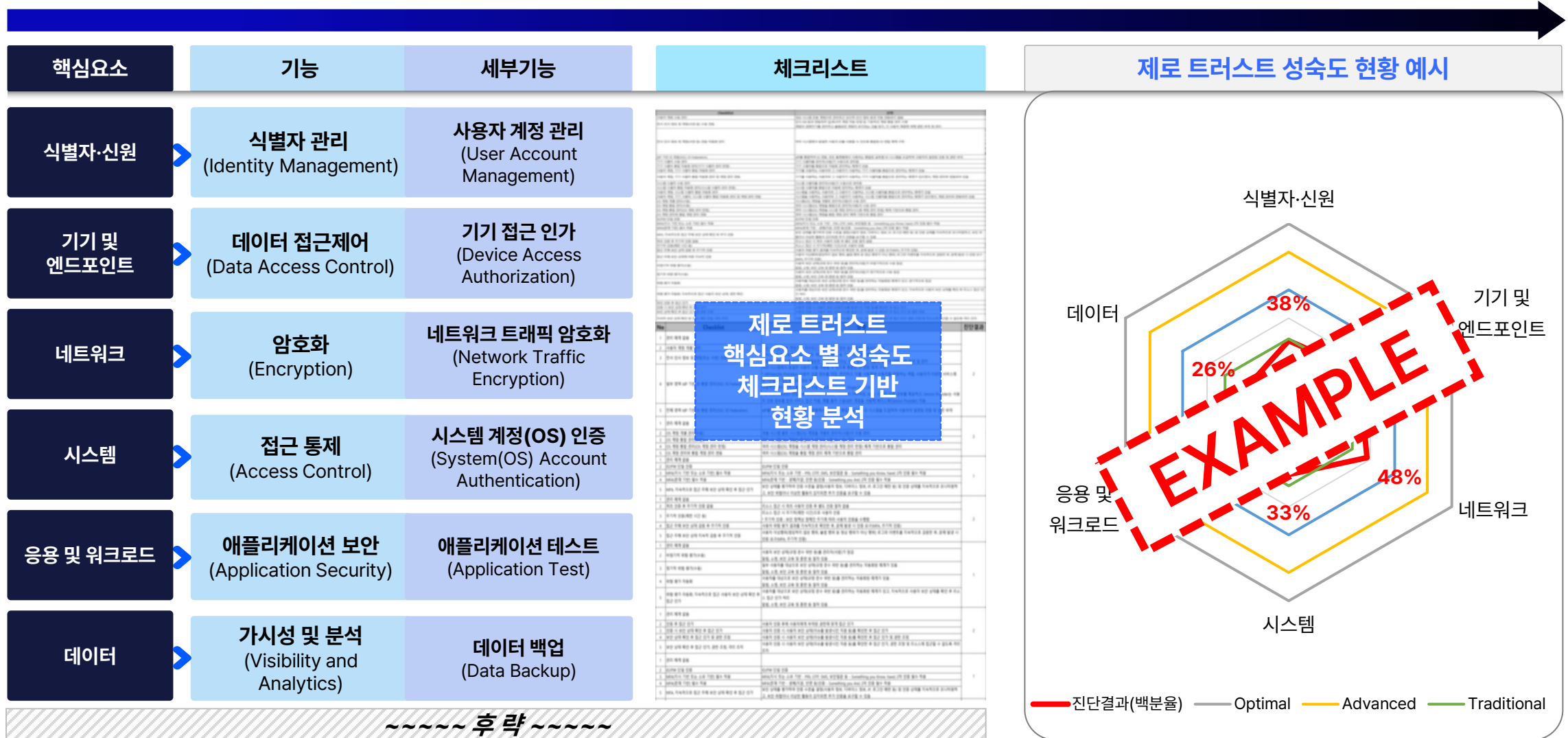
2. 제로 트러스트 아키텍처 2.0 (5/6)

목표 제로 트러스트 아키텍처 모델 구성 절차



2. 제로 트러스트 아키텍처 2.0 (6/6)

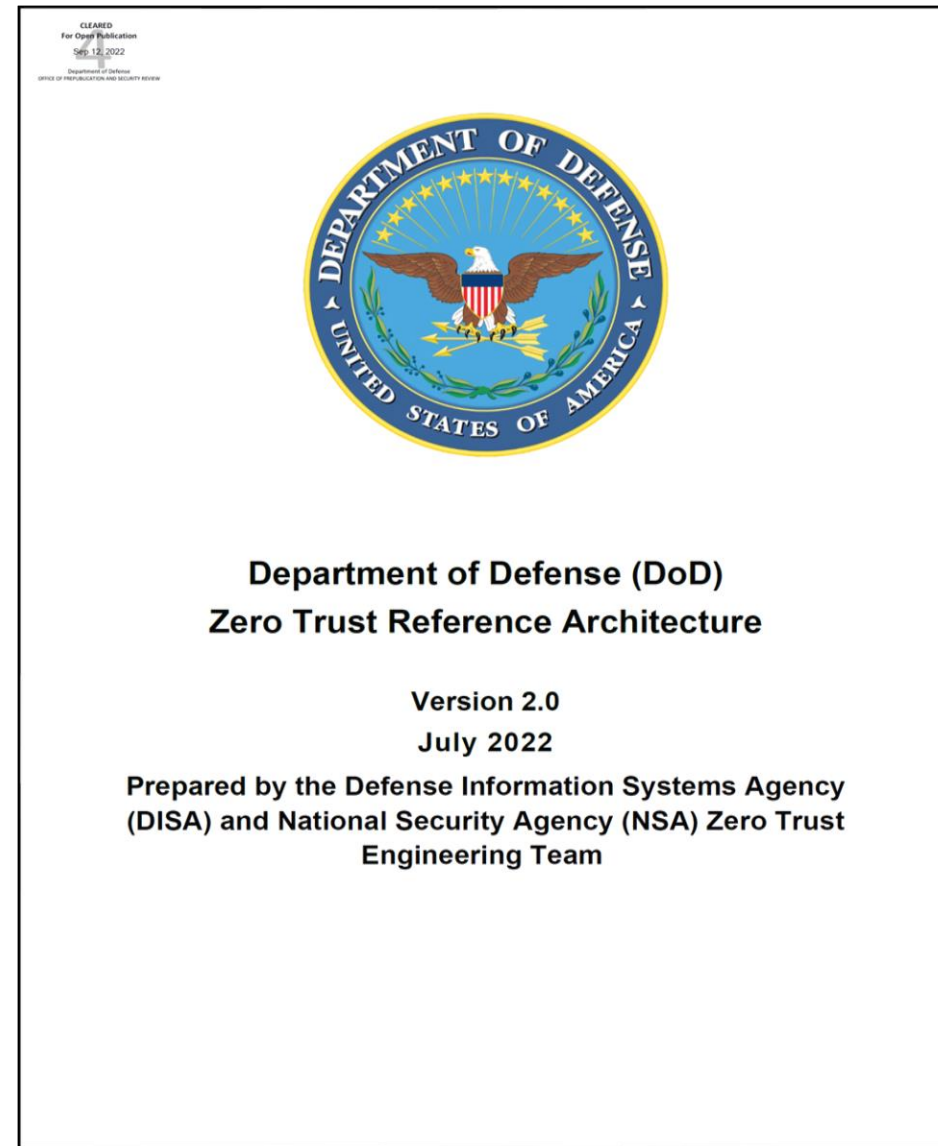
제로 트러스트 성숙도 체크리스트 도출



3. 보안 컴플라이언스와 ZTA 오버레이 (1/7)

DoD ZT Reference Architecture

- DoD 산하 DISA(Defense Information Systems Agency)와 NSA(National Security Agency)는 2022년 7월 "DoD Zero Trust Reference Architecture" v2.0을 발표함
- 본 문서는 2020년 9월30일 최초 v0.9로 시작되어 현재 v2.0에 이르고 있으며, 다음과 같은 사항들이 포함되어 있음 (전략 및 비전,기둥 및 원칙,개념적 기능 아키텍처, 유스케이스, 보안평가, 아키텍처 패턴 등)
- 본 문서에서는 유스케이스 영역에서 총 17가지의 관점에서 적용 방법론을 제시하고 있으며, ZT 성숙도 모델을 제시하고 있음
- 본 문서는 DoD 전 군에서 참조되며, 향후 확장 발전될 예정임



3. 보안 컴플라이언스와 ZTA 오버레이 (2/7)

DoD Zero Trust Capabilities

User	Device	Application & Workload	Data	Network & Environment	Automation & Orchestration	Visibility & Analytics
1.1 User Inventory	2.1 Device Inventory	3.1 Application Inventory	4.1 Data Catalog Risk Assessment	5.1 Data Flow Mapping	6.1 Policy Decision Point (PDP) & Policy Orchestration	7.1 Log All Traffic (Network, Data, Apps, Users)
1.2 Conditional User Access	2.2 Device Detection and Compliance	3.2 Secure Software Development & Integration	4.2 DoD Enterprise Data Governance	5.2 Software Defined Networking (SDN)	6.2 Critical Process Automation	7.2 Security Information and Event Management (SIEM)
1.3 Multi-Factor Authentication	2.3 Device Authorization with Real Time Inspection	3.3 Software Risk Management	4.3 Data Labeling and Tagging	5.3 Macro Segmentation	6.3 Machine Learning	7.3 Common Security and Risk Analytics
1.4 Privileged Access Management	2.4 Remote Access	3.4 Resource Authorization & Integration	4.4 Data Monitoring and Sensing	5.4 Micro Segmentation	6.4 Artificial Intelligence	7.4 User and Entity Behavior Analytics
1.5 Identity Federation & User Credentialing	2.5 Partially & Fully Automated Asset, Vulnerability and Patch Management	3.5 Continuous Monitoring and Ongoing Authorizations	4.5 Data Encryption & Rights Management		6.5 Security Orchestration, Automation & Response (SOAR)	7.5 Threat Intelligence Integration
1.6 Behavioral, Contextual ID, and Biometrics	2.6 Unified Endpoint Management (UEM) & Mobile Device Management (MDM)		4.6 Data Loss Prevention (DLP)		6.6 API Standardization	7.6 Automated Dynamic Policies
1.7 Least Privileged Access	2.7 Endpoint & Extended Detection & Response (EDR & XDR)		4.7 Data Access Control		6.7 Security Operations Center (SOC) & Incident Response (IR)	
1.8 Continuous Authentication						
1.9 Integrated ICAM Platform						

EXECUTION ENABLERS



Doctrine



Organization



Training



Material



Leadership & Education



Personnel



Facilities



Policy

실행 지원 능력: Doctrine(원칙), Organization(조직), Training(훈련), Material(바탕), Leadership(리더십), Personnel(인력), Facilities(설비), Policy(정책)

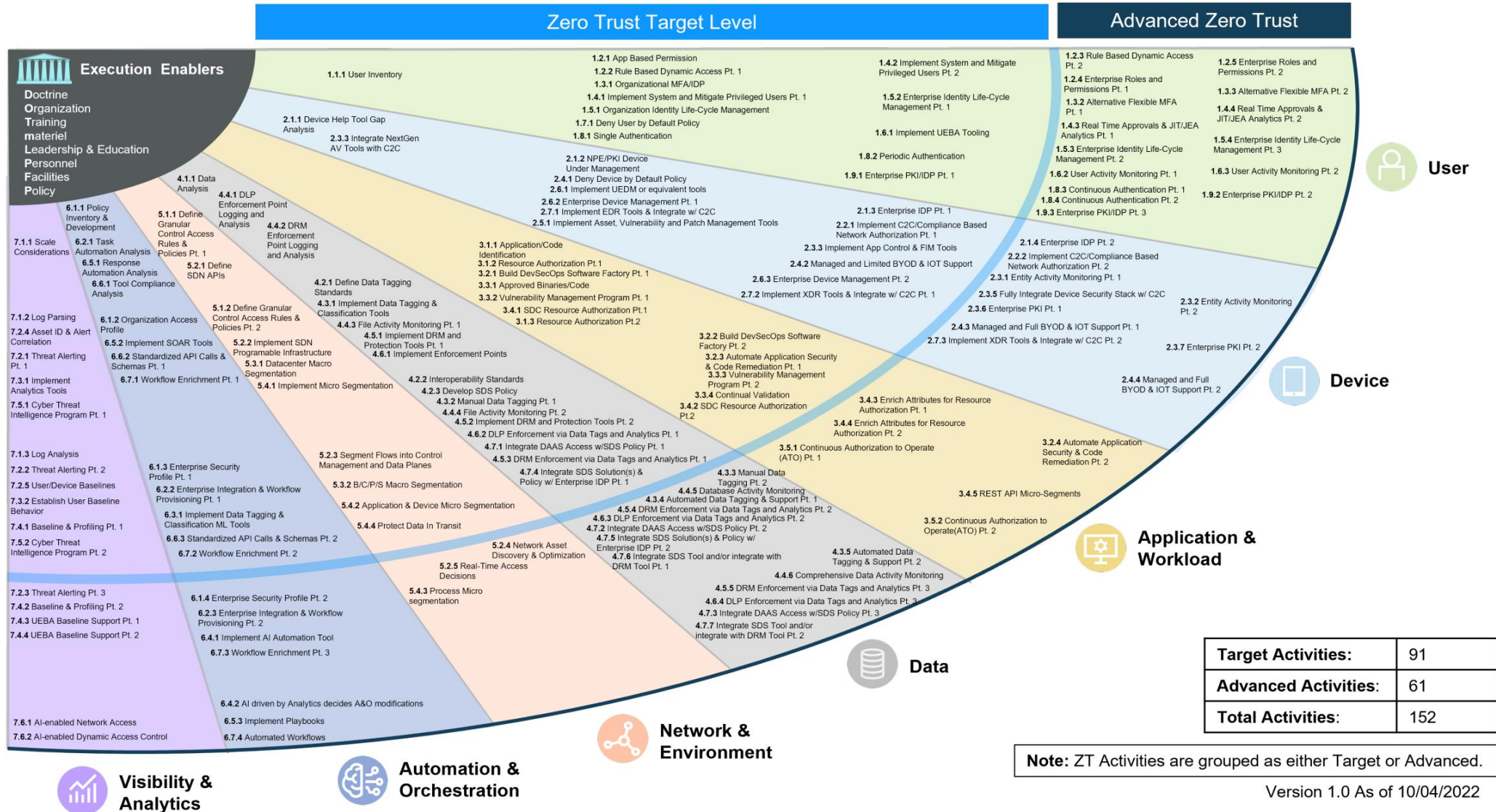
3. 보안 컴플라이언스와 ZTA 오버레이 (3/7)

Target & Advanced Levels

		Target		Target & Advanced		Advanced			
	User	1.1 User Inventory	1.7 Least Privileged Access	1.2 Conditional User Access 1.3 Multifactor Authentication 1.4 Privileged Access Mgmt. 1.5 Identity Federation and User Credentialing	1.6 Behavioral, Contextual ID, & Biometrics 1.8 Continuous Authentication 1.9 Integrated ICAM Platform				
	Device	2.5 Partially & Fully Automated Asset, Vulnerability and Patch Mgmt.	2.6 Unified Endpoint Management (UEM) & Mobile Device Management (MDM)	2.1 Device Inventory 2.2 Device Detection and Compliance 2.3 Device Authorization w/ Real Time Inspection	2.4 Remote Access 2.7 Endpoint & Extended Detection & Response (EDR & XDR)				
	Application & Workload	3.1 Application Inventory	3.3 Software Risk Management	3.2 Secure Software Development & Integration	3.4 Resource Authorization & Integration	3.5 Continuous Monitoring and Ongoing Authorizations			
	Data	4.1 Data Catalog Risk Alignment	4.2 DoD Enterprise Data Governance	4.3 Data Labeling & Tagging 4.4 Data Monitoring & Sensing 4.5 Data Encryption & Rights Management	4.6 Data Loss Prevention (DLP) 4.7 Data Access Control				
	Network & Environment	5.1 Data Flow Mapping	5.3 Macro Segmentation	5.2 Software Defined Networking	5.4 Micro Segmentation				
	Automation & Orchestration	6.3 Machine Learning	6.6 API Standardization	6.1 Policy Decision Point (PDP) & Policy Orchestration 6.2 Critical Process Automation	6.5 Security Orchestration, Automation & Response (SOAR) 6.7 Security Operation Center (SOC) & Incident Response (IR)	6.4 Artificial Intelligence			
	Visibility & Analytics	7.1 Log All Traffic	7.3 Common Security & Risk Analytics 7.5 Threat Intelligence Integration	7.2 Security Information and Event Mgmt. (SIEM)	7.4 User & Entity Behavior Analytics (UEBA)	7.6 Automated Dynamic Policies			
EXECUTION ENABLERS		Doctrine	Organization	Training	materiel	Leadership & Education	Personnel	Facilities	Policy

3. 보안 컴플라이언스와 ZTA 오버레이 (4/7)

Zero Trust Target Level



3. 보안 컴플라이언스와 ZTA 오버레이 (5/7)

DoD Zero Trust Overlays

- DoD Zero Trust Overlay는 미 국방부의 ZTRA의 구현 내용이 어떻게 SP 800-53의 통제항목과 오버레이가 되는지 설명하는 자료로 2024년 7월에 발표됨
- NIST CSF와 SP 800-53은 보안 규정과 통제 항목에 기반을 둔 것이라면 NIST SP 800-207 Zero Trust Architecture는 제로 트러스트 개념에 기반을 둔 IT 보안 체계의 기술적 구현 방법론임
- 본 문서는 미 국방부가 설계한 제로 트러스트 참조 아키텍처의 기술적 구현이 주요 보안통제 항목 표준인 SP 800-53의 보안통제 항목을 어떻게 만족시키는지 설명해주는 자료임

Department of Defense Zero Trust Overlays



Office of the Chief Information Officer

June 2024
(Version 1.1)

CLEARED
For Open Publication
Jun 27, 2024

Department of Defense
OFFICE OF PREPUBLICATION AND SECURITY REVIEW

ii

3. 보안 컴플라이언스와 ZTA 오버레이 (6/7)

DoD Zero Trust Overlay 세부 내용

A.1 Allocation of Access Control Controls to Zero Trust Pillars/Enabler

Table A-1. Access Control (AC) Family Controls Allocated to Zero Trust Pillars/Enabler

Applicable Controls		Pillars/Enablers						
		Enabler	User	Device	Application & Workload	Data	Network & Environment	Automation & Orchestration Visibility & Analytics
AC-1	Policy and Procedures	X						X
AC-2	Account Management		X	X	X			X
AC-2(1)	Automated System Account Management		X					
AC-2(2)	Automated Temporary and Emergency Account Management		X					
AC-2(3)	Disable Accounts		X					
AC-2(4)	Automated Audit Actions		X					
AC-2(6)	Dynamic Privilege Management		X	X				X
AC-2(7)	Privileged User Accounts		X					
AC-2(8)	Dynamic Account Management		X					
AC-2(9)	Restrictions on Use of Shared and Group Accounts		X					
AC-2(11)	Usage Conditions		X					X
AC-2(12)	Account Monitoring for Atypical Usage	X	X					X
AC-2(13)	Disable Accounts for High-risk Individuals		X					
AC-3	Access Enforcement		X	X	X	X	X	X
AC-3(7)	Role-based Access Control		X	X			X	
AC-3(8)	Revocation of Access Authorizations		X	X				X
AC-3(10)	Audited Override of Access Control Mechanisms		X					
AC-3(11)	Restrict Access to Specific Information Types		X	X		X		X
AC-3(12)	Assert and Enforce Application Access				X			
AC-3(13)	Attribute-based Access Control		X	X	X	X	X	X
AC-4	Information Flow Enforcement				X	X	X	
AC-4(1)	Object Security and Privacy Attributes				X	X	X	
AC-4(2)	Processing Domains						X	
AC-4(3)	Dynamic Information Flow Control				X	X	X	X
AC-4(6)	Metadata					X	X	X
AC-4(8)	Security and Privacy Policy Filters				X	X	X	X
AC-4(10)	Enable and Disable Security or Privacy Policy Filters				X	X	X	X
AC-4(11)	Configuration of Security or Privacy Policy Filters				X	X	X	X
AC-4(12)	Data Type Identifiers				X	X		
AC-4(17)	Domain Authentication			X		X		
AC-4(19)	Validation of Metadata				X	X	X	
AC-4(21)	Physical or Logical Separation of Information Flows						X	
AC-4(23)	Modify Non-releasable Information				X			
AC-4(26)	Audit Filtering Actions				X			
AC-4(29)	Filter Orchestration Engines							X

A-2

A.5 Allocation of Configuration Management Controls to Zero Trust Pillars/Enabler

Table A-5. Configuration Management (CM) Family Controls Allocated to Zero Trust Pillars/Enabler

Applicable Controls		Pillars/Enablers						
		Enabler	User	Device	Application & Workload	Data	Network & Environment	Automation & Orchestration Visibility & Analytics
CM-1	Policy and Procedures	X						
CM-2	Baseline Configuration			X	X			
CM-2(2)	Automation Support for Accuracy and Currency			X	X			
CM-2(6)	Development and Test Environments			X	X			
CM-3	Configuration Change Control			X	X			
CM-3(1)	Automated Documentation, Notification, and Prohibition of Changes				X			
CM-3(2)	Testing, Validation, and Documentation of Changes				X			
CM-3(3)	Automated Change Implementation				X			
CM-3(5)	Automated Security Response			X				
CM-4	Impact Analyses				X			
CM-4(1)	Separate Test Environments				X			
CM-4(2)	Verification of Controls				X			
CM-6	Configuration Settings			X	X			
CM-6(1)	Automated Management, Application, and Verification			X	X			
CM-6(2)	Respond to Unauthorized Changes			X				
CM-7	Least Functionality				X			
CM-7(2)	Prevent Program Execution			X				
CM-7(5)	Authorized Software — Allow-by-exception			X				
CM-7(8)	Binary or Machine Executable Code			X	X			
CM-8	System Component Inventory			X	X			
CM-8(2)	Automated Maintenance			X				
CM-8(3)	Automated Unauthorized Component Detection			X				
CM-8(6)	Assessed Configurations and Approved Deviations			X				
CM-8(9)	Assignment of Components to Systems			X	X			
CM-9	Configuration Management Plan			X	X			
CM-10	Software Usage Restrictions				X			
CM-10(1)	Open-source Software				X			
CM-11	User-installed Software			X				
CM-11(3)	Automated Enforcement and Monitoring			X				
CM-12	Information Location						X	
CM-14	Signed Components			X				

A-7

User Pillar Controls Capability 1.5: Identity Federation and User Credentialing		Phased Activities				Overlay-specific Parameter Values
		1.5.1 Organization Identity Lifecycle Mgmt	1.5.2 Enterprise ILM Part 1	1.5.3 Enterprise ILM Part 2	1.5.4 Enterprise ILM Part 3	
AC-6	Least Privilege					
AC-6(5)	Privileged Accounts	X				
AC-6(7)	Review of User Privileges	X				
AU-2	Event Logging	X	X			e. At least annually, or more frequently for more critical mission/business functions
AU-3	Content of Audit Records	X	X			
AU-8	Time Stamps	X	X			b. 1 (one) millisecond
AU-9	Protection of Audit Information	X	X			
AU-9(4)	Access by Subset of Privileged Users	X	X			
AU-10	Non-repudiation	X	X			
AU-10(1)	Association of Identities	X	X			
AU-12	Audit Record Generation	X	X			b. Security Administrator
IA-1	Policy and Procedures	X	X			
IA-2	Identification and Authentication (organizational user)	X	X			
IA-4	Identifier Management	X	X			
IA-4(4)	Identify User Status	X	X			
IA-4(5)	Dynamic Management			X		
IA-4(6)	Cross-Organization Management			X		
IA-4(9)	Attribute Maintenance and Protection	X	X			Authoritative Attribute Sources or Attribute Services Policy Information Points
IA-5	Authenticator Management	X	X			2 nd PV: any suspected compromise of an authenticator
IA-5(9)	Federated Credential Management			X		
IA-5(10)	Dynamic Credential Binding	X		X		
IA-8	Identification and Authentication (non-organizational user)		X			
IA-8(1)	Acceptance of PIV Credentials from Other Agencies		X			
IA-8(5)	Acceptance of PIV-I Credentials		X			requirements in FIPS 201-3
IA-12	Identity Proofing	X	X			
PL-4	Rules of Behavior	X				

C-39

국가 망 보안체계(N²SF) 가이드라인 - 국가 망 보안체계 기반 제로 트러스트 적용 방법

제1절

국가 망 보안체계 기반 제로트러스트 적용 방법

국가 망 보안체계의 보안통제 항목은 NIST RMF가 제공하는 오버레이(Overlay) 개념을 적용할 수 있다. 따라서 제로트러스트, 공급망 보안, 회복력 등을 위한 오버레이를 위험관리 활동에 적용할 수 있다. 그렇게 되면, 범용적인 보안통제 항목을 제로트러스트, 공급망 보안, 회복력 관점에서 특화된 내용으로 설계하고 구현할 수 있게 된다.

다음은 미국 국방성(DoD)의 제로트러스트 오버레이를 나타낸다. 이를 이용하면 보안통제 항목에 대해서 제로트러스트 관점의 기능성을 판단할 수 있으며, 결과적으로 조직은 제로트러스트 보안목표 달성을 위해 특정 보안통제 항목을 추가하거나 제로트러스트 기능성 강화를 위해 보안통제 항목의 세부사항을 조정할 수 있다.

그림 참고-1 보안통제 항목에 대한 Zero Trust 오버레이

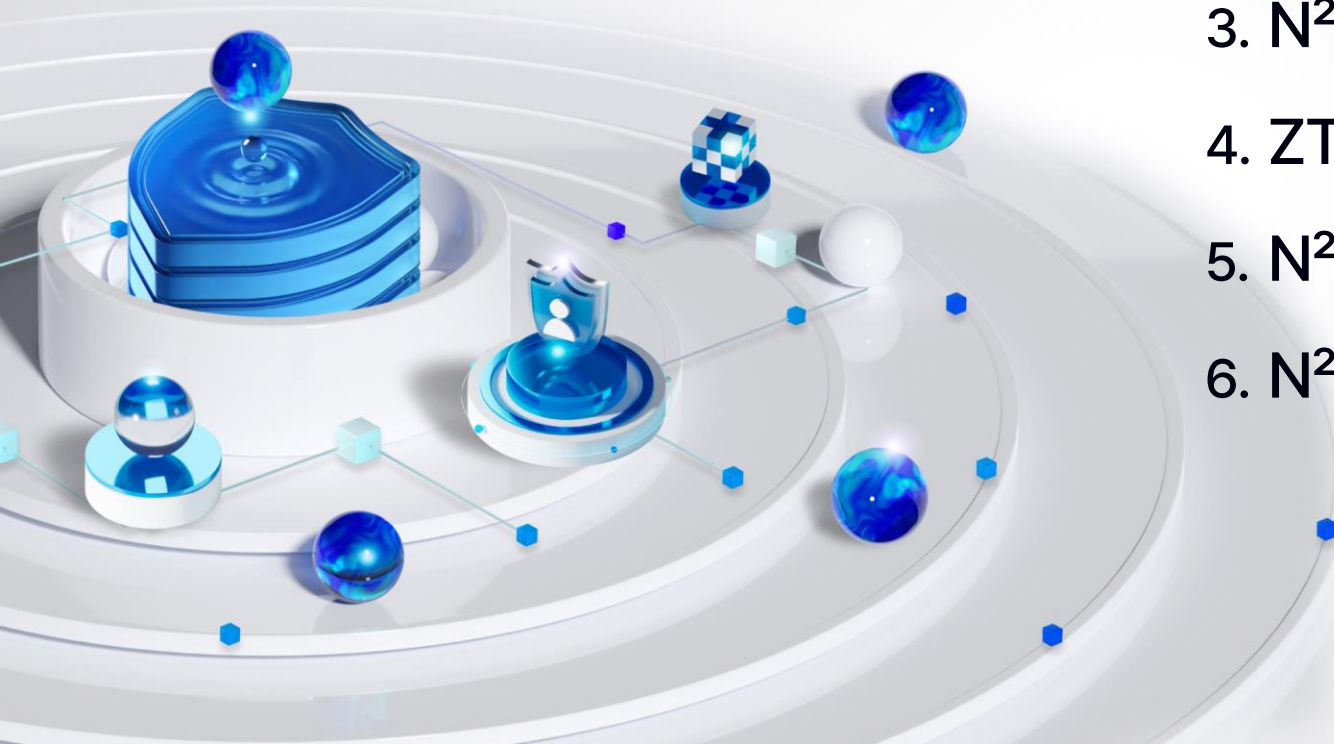
Applicable Controls		Pillars/Enablers						
		Enabler	User	Device	Application & Workload	Data	Network & Environment	Automation & Orchestration
PT-1	Policy and Procedures	X						
PT-2	Authority to Process Personally Identifiable Information					X		X
PT-2(1)	Data Tagging					X		X
PT-2(2)	Automation					X		X

* 출처: DoD Zero Trust Overlays, June 2024

II

N²SF & ZTA Overlay

1. N²SF 가이드라인
2. N²SF 보안통제항목 해설서 (부록1)
3. N²SF 정보서비스 모델 해설서 (부록2)
4. ZT 가이드라인 2.0 vs. SGA ZTA 오버레이
5. N²SF vs. SGA ZTA 오버레이
6. N²SF vs. ZT 2.0 vs. SGA ZTA 오버레이



" 국가 망 보안체계(N²SF) 가이드라인 "

- 5단계 도입 절차 [준비 → C/S/O 등급분류 → 위협식별 → 보안대책 수립 → 적절성 평가·조정]
- 정부 전산망 업무 중요도에 따라 기밀(Classified)·민감(Sensitive)·공개(Open) 등급으로 분류



6개 부문 178개의 보안통제 항목
(보안통제 항목 해설서-부록1)

 권한: 28개
  인증: 38개
  분리 및 격리: 9개

 통제: 49개
  데이터: 18개
  정보자산: 36개

8개의 정보서비스 모델 (정보서비스 모델 해설서-부록2)

1. 인터넷 단말의 업무 활용성 제고
 2. 업무환경에서의 생성형 AI 활용
 3. 외부 클라우드 활용 업무협업 재개
 4. 업무단말의 인터넷 이용
 5. 공공 데이터의 외부 AI 융합
 6. 연구 목적 단말의 신기술 활용
 7. 개발 환경 편의성 향상
 8. 클라우드 기반 통합문서체계

각 부문별 보안통제 항목
설명 및 N²SF 우선
검토사항 (C/S/O 적용)
제시

보안관리 정책 종합

대역	유형	NFSP ID	소속	보안정책	NFSP 인증 가능
민간 최소한의 Least Privilege (LP)	민간소유	NFSP-1-1	민간소유	민간소유	● ●
	민간소유	NFSP-1-2	민간소유	민간소유	● ●
	민간소유	NFSP-1-3	민간소유	민간소유	● ●
	민간소유	NFSP-1-4	민간소유	민간소유	● ●
	민간소유	NFSP-1-5	민간소유	민간소유	● ●
	민간소유	NFSP-1-6	민간소유	민간소유	● ●
	민간소유	NFSP-1-7	민간소유	민간소유	● ●
	민간소유	NFSP-1-8	민간소유	민간소유	● ●
	민간소유	NFSP-1-9	민간소유	민간소유	● ●
	민간소유	NFSP-1-10	민간소유	민간소유	● ●
국립 최소한의 Least Privilege (LP)	국립소유	NFSP-2-1	국립소유	국립소유	● ●
	국립소유	NFSP-2-2	국립소유	국립소유	● ●
	국립소유	NFSP-2-3	국립소유	국립소유	● ●
	국립소유	NFSP-2-4	국립소유	국립소유	● ●
	국립소유	NFSP-2-5	국립소유	국립소유	● ●
	국립소유	NFSP-2-6	국립소유	국립소유	● ●
	국립소유	NFSP-2-7	국립소유	국립소유	● ●
	국립소유	NFSP-2-8	국립소유	국립소유	● ●
	국립소유	NFSP-2-9	국립소유	국립소유	● ●
	국립소유	NFSP-2-10	국립소유	국립소유	● ●
군사 최소한의 Least Privilege (LP)	군소유	NFSP-3-1	군소유	군소유	● ●
	군소유	NFSP-3-2	군소유	군소유	● ●
	군소유	NFSP-3-3	군소유	군소유	● ●
	군소유	NFSP-3-4	군소유	군소유	● ●
	군소유	NFSP-3-5	군소유	군소유	● ●
	군소유	NFSP-3-6	군소유	군소유	● ●
	군소유	NFSP-3-7	군소유	군소유	● ●
	군소유	NFSP-3-8	군소유	군소유	● ●
	군소유	NFSP-3-9	군소유	군소유	● ●
	군소유	NFSP-3-10	군소유	군소유	● ●
정부 최소한의 Least Privilege (LP)	정부소유	NFSP-4-1	정부소유	정부소유	● ●
	정부소유	NFSP-4-2	정부소유	정부소유	● ●
	정부소유	NFSP-4-3	정부소유	정부소유	● ●
	정부소유	NFSP-4-4	정부소유	정부소유	● ●
	정부소유	NFSP-4-5	정부소유	정부소유	● ●
	정부소유	NFSP-4-6	정부소유	정부소유	● ●
	정부소유	NFSP-4-7	정부소유	정부소유	● ●
	정부소유	NFSP-4-8	정부소유	정부소유	● ●
	정부소유	NFSP-4-9	정부소유	정부소유	● ●
	정부소유	NFSP-4-10	정부소유	정부소유	● ●
민간 최소한의 Least Privilege (LP)	민간소유	NFSP-5-1	민간소유	민간소유	● ●
	민간소유	NFSP-5-2	민간소유	민간소유	● ●
	민간소유	NFSP-5-3	민간소유	민간소유	● ●
	민간소유	NFSP-5-4	민간소유	민간소유	● ●
	민간소유	NFSP-5-5	민간소유	민간소유	● ●
	민간소유	NFSP-5-6	민간소유	민간소유	● ●
	민간소유	NFSP-5-7	민간소유	민간소유	● ●
	민간소유	NFSP-5-8	민간소유	민간소유	● ●
	민간소유	NFSP-5-9	민간소유	민간소유	● ●
	민간소유	NFSP-5-10	민간소유	민간소유	● ●

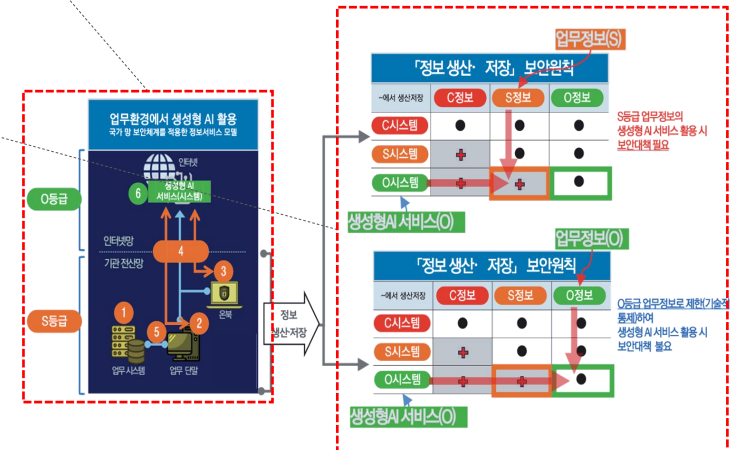
NFSP ID	보안정책 설명
NFSP-1-1~6	기밀·중요한 자료의 안전성과 신뢰성을 보장하기 위하여, 다른 정보로부터 분리, 저장·처리·관리·폐기·처분·처리가 가능한 형태로 분리·처리·관리·폐기·처분·처리가

각 부문별 보안통제
항목에 대한 구현 방법
예시 제공

정보서비스 모델별
구성요소 분석 및 [위치-
주체-객체] 모델링을 통한
C/S/O 평가 제공

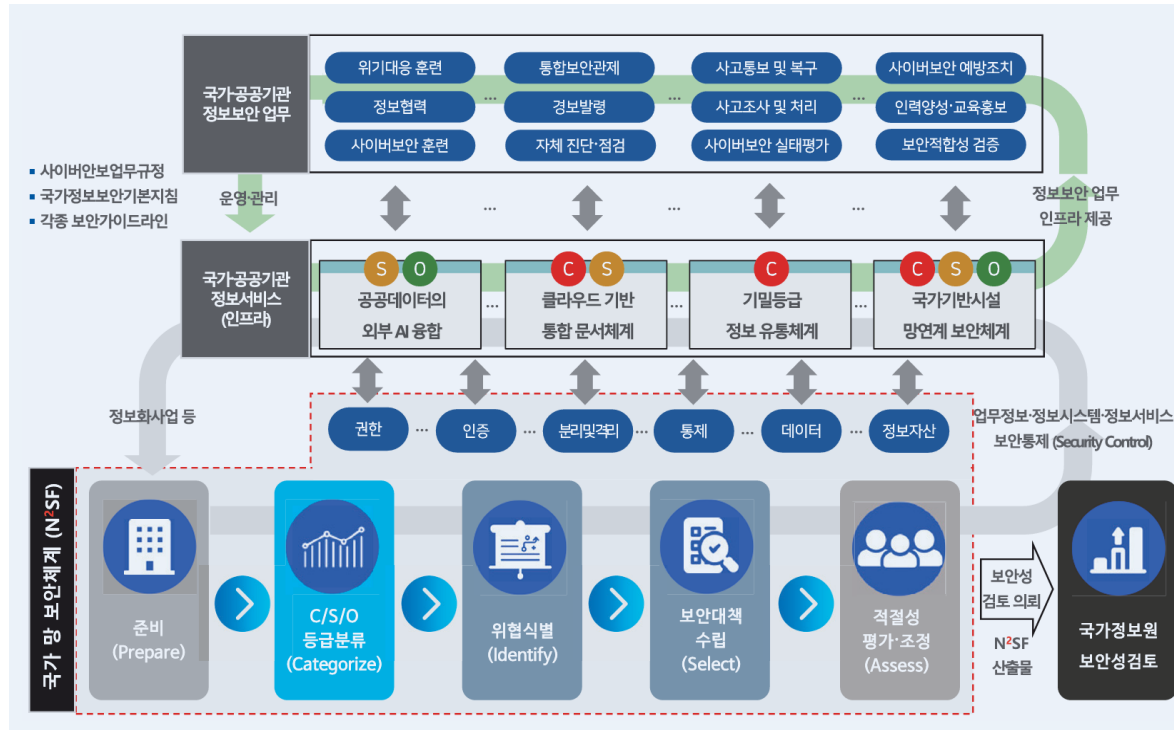
[정보 생산저장] 및
[정보 이동] 보안원칙
적용 방안 제공

모델 별 보안위협을 소개
및 정보서비스 구성요소
별 보안 요구사항에 따른
보안통제 항목 적용 방안
제시



1. N²SF 가이드라인 (2/5)

국가 망 보안체계 적용 절차 요약

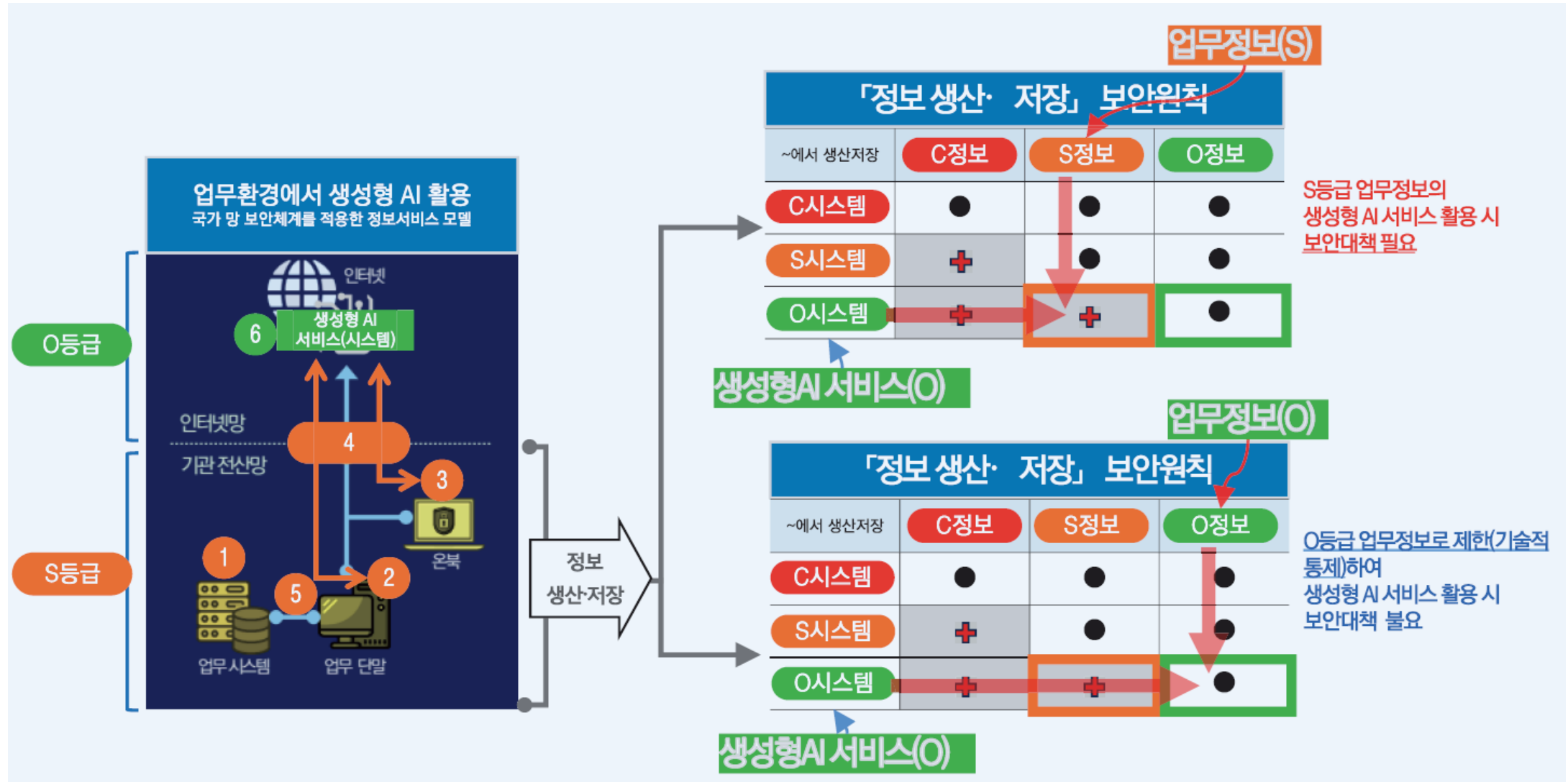


절차(단계)	주요 활동 (요약)	수행주체
준비 (Prepare)	▶ [NNSF-P-1] N²SF 적용계획 수립 ▶ [NNSF-P-2] 기관 업무·기능 분석 ▶ [NNSF-P-3] 업무정보 식별 ▶ [NNSF-P-4] 정보시스템 식별 ▶ [NNSF-P-5] 정보서비스 식별	각급 기관
C/S/O 등급분류 (Categorize)	▶ [NNSF-C-1] 업무정보 C/S/O 분류 ▶ [NNSF-C-2] 정보시스템 C/S/O 분류	각급 기관
위협식별 (Identify)	▶ [NNSF-I-1] 정보서비스 구성요소 분석 ▶ [NNSF-I-2] 모델링 및 C/S/O 평가 ▶ [NNSF-I-3] 보안원칙 적용	각급 기관
보안대책 수립 (Select)	▶ [NNSF-S-1] 보안통제 선택 ▶ [NNSF-S-2] 보안통제 조정 (필요시) ▶ [NNSF-S-3] 보안통제 구현계획 수립	각급 기관
적절성 평가·조정 (Assess)	▶ [NNSF-A-1] 단계별 적절한성 평가 ▶ [NNSF-A-2] 적절한성 평가결과 협의·조정(미비점 보완 등) ▶ [NNSF-A-3] 적절한성 평가결과 승인	각급 기관

* NNSF: National Network Security Framework

1. N²SF 가이드라인 (3/5)

☞ [위협식별] 단계 보안원칙 적용(NNSF-I-3) 예시



1. N²SF 가이드라인 (4/5)

☞ [보안대책 수립] 단계 보안통제 선택(NNSF-S-1) 예시

S'등급 업무정보·정보시스템

S'등급 기준선

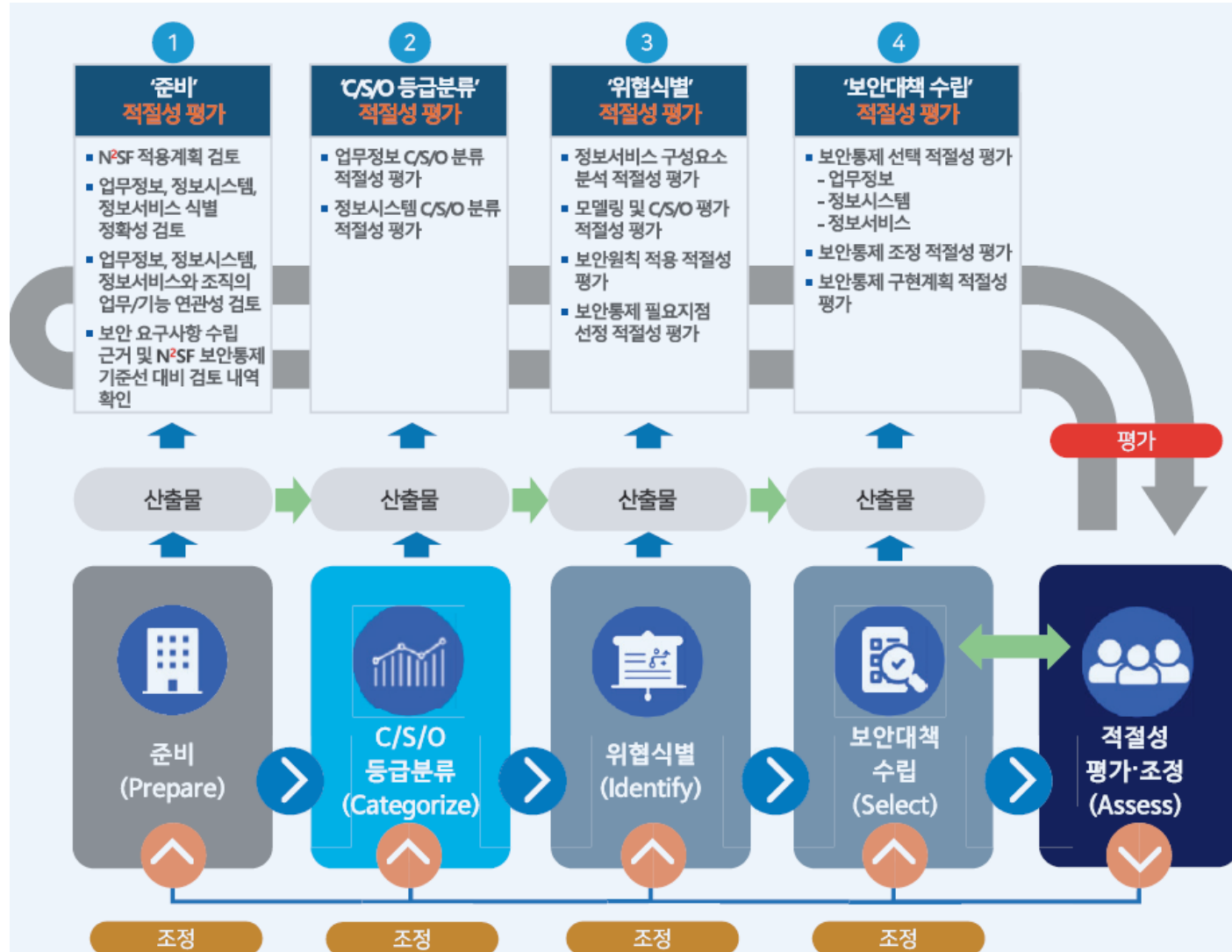
대항목	중항목	N ² SF 보안통제 ID	소항목	N ² SF 보안통제 기준선(Baseline)			설명
				O (공개)	S (민감)	C (기밀)	
인증	다중요소 인증	NNSF-MA-1	관리자 계정 다중요소 인증(MFA, Multi-factor Authentication)	●	●	●	
		NNSF-MA-2	사용자 계정 다중요소 인증(MFA, Multi-factor Authentication)	●	●	●	
		NNSF-MA-3	다중요소 인증 장치 분리			●	
		NNSF-MA-4	다중요소 인증(MFA, Multi-factor Authentication) 경로 분리		●	●	
...							
통제	원격접속	NNSF-RA-1	원격접속 모니터링 및 통제		●	●	
		NNSF-RA-2	원격접속 세션 암호화		●	●	

'S'등급 업무정보·정보시스템

'S'등급 기준선

1. N²SF 가이드라인 (5/5)

㉮ 적절성 평가·조정 단계



2. N²SF 보안통제 항목 해설서 (부록1)

☞ [부록1] 보안통제 항목 해설서

- 6개 부문 178개의 보안통제 항목에 대한 정의 및 설명, 구현 방법 예시 소개
(권한 : 28개, 인증 : 38개, 분리 및 격리 : 9개, 통제 : 49개, 데이터 : 18개, 정보자산 : 36개)

대항목	중항목	NNSF ID	소항목	보안통제설명	N²SF 우선 검토사항 C 기밀 S 민감 O 공개
권한	최소권한 Least Privilege (LP)	NNSF-LP-1	정보시스템 접근 권한 정의	업무정보(데이터)를 식별하고, 업무정보를 저장하고 있는 정보시스템 접근 권한을 정의한다.	● ●
		NNSF-LP-2	보안통제 권한 제한	보안통제 권한은 정보보안담당(자) 또는 이에 준하는 관리권한을 부여받은 인원에게만 부여한다.	● ● ●
		NNSF-LP-3	보안통제 계정 노출 방지	보안통제 권한 목적으로 사용되는 계정과 이의 기능에 사용되는 계정은 중복 사용하지 않도록 보안통제 권한 계정의 노출을 방지한다.	● ● ●
		NNSF-LP-4	원격접속을 통한 관리자 권한 접속제한	기관 네트워크 내부에서 관리자 권한 접속이 제한되는 경우 등 불가피한 상황에서만 한시적으로 기관 네트워크 외부에서의 관리자 권한 접속을 허용하며, 목적이 달성된 경우 외부에서의 관리자 권한 접속을 즉시 차단한다.	- ● ●
		NNSF-LP-5	관리자 권한 제한	정보시스템 관리자 권한은 관리자 및 운영자 등 최소한의 인원에게만 부여한다.	● ●
		NNSF-LP-6	기관 이외 인원의 관리자 권한 제한	기관 구성원 이외 인원에 관리자 권한은 부여하지 않으며, 다만 정보보안 감사, 사이버보안 실태평가, 사고 조사 및 진단·점검 등에 필요한 경우 외부 인원에 관리자 권한을 한시적으로 부여할 수 있다.	● ● ●
		NNSF-LP-7	사용자에게 부여된 관리자 권한 관리	사용자에게 관리자 권한이 부여된 경우 주기적으로 지속 필요 여부를 검토하고 불필요한 경우 권한을 삭제한다.	-
		NNSF-LP-8	코드 실행권한 제한	코드는 필요한 권한으로만 실행되도록 제한하고, 사용자 권한으로 실행되는 코드가 관리자 영역으로 접근되지 않도록 차단한다.	● ● ●
		NNSF-LP-9	관리자 권한 실행 로깅 및 감사	관리자 권한 기능 실행 내역은 로깅하고 주기적인 사용 내역 감사를 실시한다.	● ● ●
	신원검증 Identity Verification (IV)	NNSF-IV-1	관리자 승인	정보시스템 사용자 계정(대민서비스 등 서비스 이용자 계정 제외) 부여를 위한 계정 등록 절차에 정보시스템 관리자(정보화담당관 또는 이에 준하는 관리자)의 승인을 포함한다.	● ●
		NNSF-IV-2	신원 증거 제출	개인은 신원을 증명할 수 있는 증거를 등록 기관에 제출한다.	● ●
		NNSF-IV-3	신원 증거 검증	제출된 신원 증거를 검증한다.	● ●

1. 최소 권한 (Least Privilege, LP)

■ 정의

최소 권한은 사용자나 프로세스가 특정 업무를 수행하는 데 필요한 최소한의 권한만을 부여하는 보안 원칙으로, 내부 및 외부 위협으로부터 시스템을 보호하고, 내부 정보의 불필요한 접근을 방지하기 위한 통제항목이다.

■ 보안통제 항목

NNSF ID	보안통제 항목 설명
NNSF-LP-1	C S 정보시스템 접근 권한 정의 업무정보(데이터)를 식별하고, 업무정보를 저장하고 있는 정보시스템 접근 권한을 정의한다.
NNSF-LP-2	C S O 보안통제 권한 제한 보안통제 권한은 정보보안담당(자) 또는 이에 준하는 관리권한을 부여받은 인원에게만 부여한다.
NNSF-LP-3	C S O 보안통제 계정 노출 방지 보안통제 권한 목적으로 사용되는 계정과 이의 기능에 사용되는 계정은 중복 사용하지 않도록 보안통제 권한 계정의 노출을 방지한다.
NNSF-LP-4	- S O 원격접속을 통한 관리자 권한 접속 제한 기관 네트워크 내부에서 관리자 권한 접속이 제한되는 경우 등 불가피한 상황에서만 한시적으로 기관 네트워크 외부에서의 관리자 권한 접속을 허용하며, 목적이 달성된 경우 외부에서의 관리자 권한 접속을 즉시 차단한다.
NNSF-LP-5	C S 관리자 권한 제한 정보시스템 관리자 권한은 관리자 또는 운영자 등 최소한의 인원에게만 부여한다.

■ 구현 방법 예시

• 역할 기반 접근 제어(RBAC) 적용

- 사용자의 역할에 따라 각기 다른 권한을 부여하고, 최소한의 권한만 설정하여 불필요한 권한 남용을 방지한다.

• 정기적인 권한 검토

- 모든 사용자의 권한을 정기적으로 검토하여, 더 이상 필요하지 않은 권한을 제거하거나 조정한다.

• 자동화된 권한 관리 도구 사용

- 권한 관리 도구를 사용하여 조직 내 권한 설정과 변경을 중앙에서 관리하고, 최소 권한 원칙을 자동으로 적용한다.

• 시스템 프로세스 권한 설정

- 시스템에서 실행되는 각 프로세스에 대해 필요한 권한만 부여하고, 과도한 시스템 자원 접근을 차단한다.

• 권한 분리

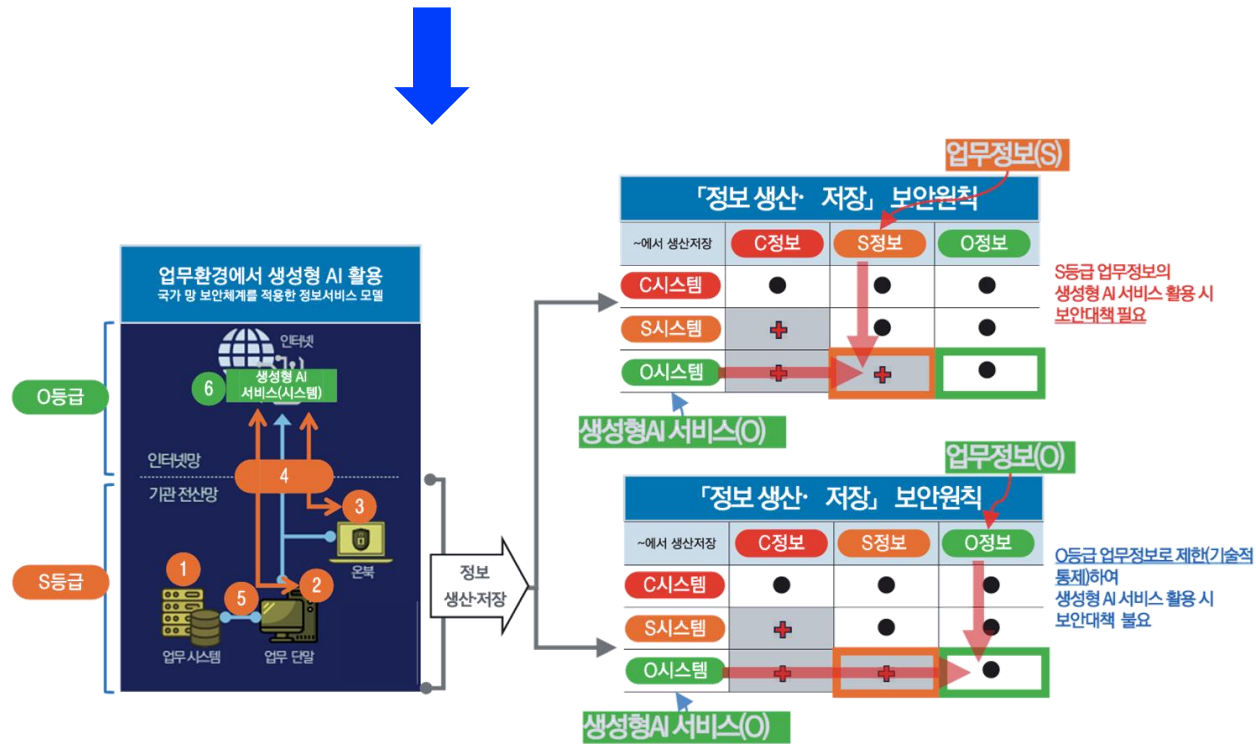
- 한 사용자가 많은 권한을 가지지 않도록 업무 및 권한을 분리하여 보안을 강화한다.

3. N²SF 정보서비스 모델 해설서 (부록2)

☞ [부록2] 정보서비스 모델 해설서

▪ 8개 정보서비스 모델에 대한 개요, 위협 식별, 보안 위협, 보안 요구사항 및 보안대책 소개

1. 인터넷 단말의 업무 활용성 제고
2. 업무환경에서의 생성형 AI 활용
3. 외부 클라우드 활용 업무협업 재개
4. 업무단말의 인터넷 이용
5. 공공 데이터의 외부 AI 융합
6. 연구 목적 단말의 신기술 활용
7. 개발 환경 편의성 향상
8. 클라우드 기반 통합문서체계



정보서비스 개요

- 정보서비스 모델에 대한 소개

위협식별

- 정보서비스 구성요소 분석
- 모델링 및 C/S/O 평가
- 보안원칙 적용 (정보 생산·저장 원칙, 정보 이동 원칙)

정보서비스에 대한 보안 위협

- 정보서비스 모델 위협 대상 식별
- 정보서비스 모델 보안 위협 요소 제시

보안 요구사항 및 보안대책

- 정보서비스 모델 대상별 보안 요구사항 및 보안대책 제시
- 보안 요구사항에 따른 N²SF 보안통제 항목 제시

4. ZT 가이드라인 2.0 vs. SGA ZTA 오버레이 (1/2)

SGA솔루션즈 SGA ZTA 솔루션 도입 시 제로 트러스트 가이드라인 2.0 충족 여부 오버레이(overlay)를 통해 관리

✓ KISA ZTA 2.0 Guideline

- 가이드라인 2.0에서는 필요 기능별 세부역량에 따른 설명과 성숙도 수준을 정의하고 있음
- 부록에는 ISMS-P 인증기준과 제로 트러스트 성숙도 모델 연계표를 제공

✓ ZTA 2.0 vs. SGA ZTA overlay

- SGA ZTA도입 시 KISA의 제로 트러스트 가이드라인 2.0에 기술 되어 있는 성숙도 모델 기반 세부역량들을 얼마나 충족할 수 있는지 overlay 방법을 통해 확인 및 관리

기능	세부기능	No.	Checklist	Overlay
1.1. 식별자 관리 (Identity Management)	1.1.1. 사용자 인벤토리 (User Account inventory)	1	관리 체계 없음	
		2	사용자 계정 목록 수집, 기본적인 사용자 정보관리 및 문서화	●
		3	일부 사용자 역할 및 권한을 포함한 상세 인벤토리 관리 및 업데이트	●
		4	전체 사용자 ID 통합 관리 시스템 구축(SSO), 비정상적인 사용자 활동 탐지 기능	●
		5	인벤토리 통합을 통한 사용자 및 권한 관리 최적화, AI 기반 사용자 행동 관리 기능	-
	1.1.2. ID연계 및 사용자 자격증명 (Identity and Access Management)	1	관리 체계 없음	
		2	사용자 자격 증명에 대한 ID 연계 솔루션 적용	●
		3	여러 시스템(내외부)간 사용자 자격 증명에 대한 연동	●
		4	데이터 보호 강화 및 다양한 ID 제공자 통합을 통한 연계연동	●
		5	글로벌 수준의 ID연계 정책 및 지속적인 최적화	●
1.2. 인증 (User Authentication)	1.2.1. 다중 인증 (Multi-Factor Authentication)	1	관리 체계 없음	
		2	기본적인 패스워드 방식과 MFA(SMS, 이메일) 구축	●
		3	인증 앱, 하드웨어 토큰 등 다양한 MFA 적용 및 FIDO 기반 인증 적용	●
		4	컨텍스트(단말 위치, 네트워크, 접속 시간 등)를 고려한 ID 인증 방식 및 상황에 따른 맞춤형 MFA 지원	●
		5	비정상적 로그인 시도 실시간 탐지 대응 및 MFA 기반 고급 보안 정책	●
	1.2.2. 지속 인증 (Continuous Authentication)	1	관리 체계 없음	
		2	세션 기반 인증, 사용자의 행동 및 접속 상태 모니터링	●
		3	모니터링을 통한 이상행위 탐지 및 추가 인증, 사용자 세션 중 추가 인증 요구 시스템	●
		4	동적 인증 기술 적용으로 실시간 인증 상태 조정 및 지속 인증을 위한 고급 분석 및 경고 기능 통합	●
		5	이상 행위 발생 시 자동 재 인증 요구, 세션 종료 등 인증에 대한 지속적 검증	●
1.3. 위험도 평가 (Risk Assessment)	1.3.1. 통합 ICAM 플랫폼	1	관리 체계 없음	
		2	기본ICAM 시스템구축(사용자 및 권한관리)	●
		3	ICAM 시스템 중앙집중형 관리, 사용자 인증 및 접근 관리정책 표준화	●
		4	다양한 보안 기술 및 시스템 통합으로 ICAM 플랫폼 안정화 및 자동화	●
		5	AI 기반의 ICAM 플랫폼을 통한 보안 강화 및 실시간 분석을 통한 ID 위험 평가	-
	1.3.2. 행동, 컨텍스트 기반ID 및 생체인식	1	관리 체계 없음	
		2	기본적인(지문, 얼굴인식) 생체 인식 기술 적용 및 사용자 행동 패턴 수동 분석	●
		3	행동 및 생체 인식 기술 통합 인증 및 컨텍스트 정보 기반 접근권한 조정	●
		4	실시간 사용자 행동 및 컨텍스트 변화 반영한 접근제어 조정	●
		5	AI 기반 행동 분석 및 생체 인식 솔루션 도입	-

4. ZT 가이드라인 2.0 vs. SGA ZTA 오버레이 (2/2)

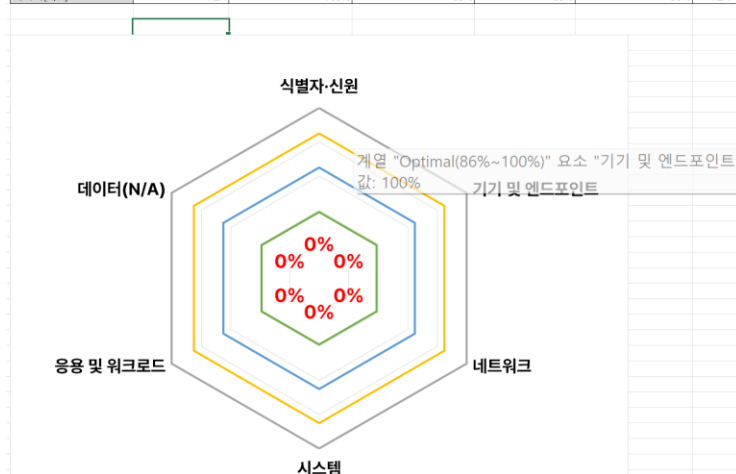
SGA솔루션즈 제로 트러스트 성숙도 진단 모델 (ZTMM)

< SGA Zero Trust Maturity Model v2.0 >

진단결과		성숙도 총점	성숙도 진단점수				성숙도 진단결과	성숙도 단계		
		0	0				#DIV/0!	#DIV/0!		
핵심요소	기능	세부기능	No	Check	범위	Checklist	진단점수	본사 솔루션	성숙도 수준	비고
1.1. 식별자 관리 (Identity Management)	1.1.1. 사용자 인벤토리 (User Account inventory)		1			관리 체계 없음	N/A	ICAM	N/A	
			2			사용자 계정 목록 수집, 기본적인 사용자 정보관리 및 문서화				
			3			일부 사용자 역할 및 권한을 포함한 상세 인벤토리 관리 및 업데이트				
			4			전체 사용자 ID 통합 관리 시스템 구축(SSO), 비정상적인 사용자 활동 탐지 가능				
			5			인벤토리 통합을 통한 사용자 및 권한 관리 최적화, AI 기반 사용자 행동 관리 가능				
	1.1.2. ID연계 및 사용자 자격증명 (Identity and Access Management)		1			관리 체계 없음	N/A	ICAM	N/A	
			2			사용자 자격 증명에 대한 ID 연계 솔루션 적용				
			3			여러 시스템(내외부)간 사용자 자격 증명에 대한 연동				
			4			데이터보호 강화 및 다양한 ID 제공자 통합을 통한 연계연동				
			5			글로벌 수준의 ID연계 정책 및 지속적인 최적화				

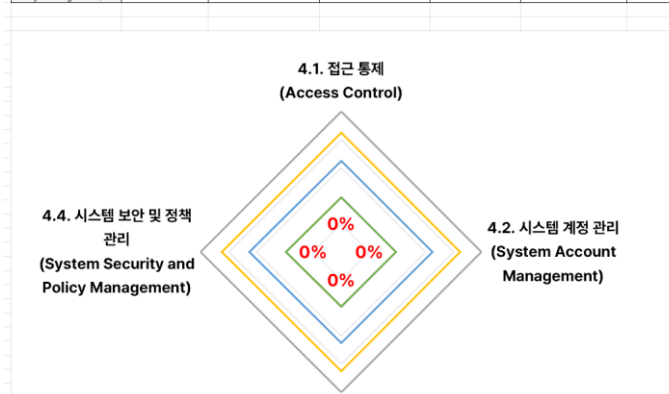
< SGA Zero Trust Maturity Model v2.0 >

구분	진단결과	Optimal(86%~100%)	Advanced(66%~85%)	Initial(40%~65%)	Traditional(1%~39%)	만점
식별자신원	#REF!	100%	85%	65%	39%	#REF!
기기 및 엔드포인트	#REF!	100%	85%	65%	39%	#REF!
네트워크	#REF!	100%	85%	65%	39%	#REF!
시스템	#REF!	100%	85%	65%	39%	#REF!
응용 및 워크로드	#REF!	100%	85%	65%	39%	#REF!
데이터(N/A)	#REF!	100%	85%	65%	39%	#REF!



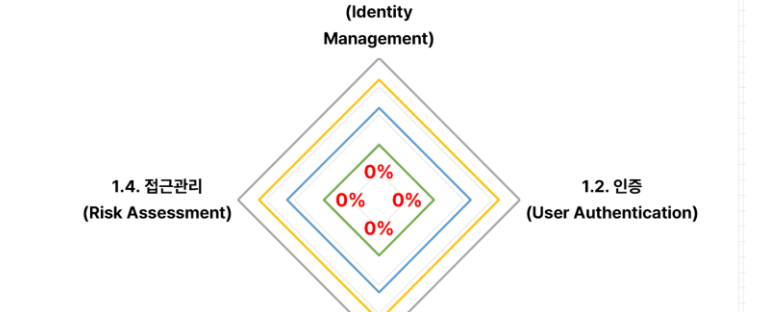
< SGA Zero Trust Maturity Model v2.0 >

#REF!	진단결과	Optimal(86%~100%)	Advanced(66%~85%)	Initial(40%~65%)	Traditional(1%~39%)	만점
4.1. 접근 통제 (Access Control)	-	100%	85%	65%	39%	0
4.2. 시스템 계정 관리 (System Account Management)	-	100%	85%	65%	39%	0
4.3. 네트워크 분리 정책 (Network Segmentation Policy)	-	100%	85%	65%	39%	0
4.4. 시스템 보안 및 정책 관리 (System Security and Policy Management)	-	100%	85%	65%	39%	0



< SGA Zero Trust Maturity Model v2.0 >

#REF!	진단결과	Optimal(86%~100%)	Advanced(66%~85%)	Initial(40%~65%)	Traditional(1%~39%)	만점
1.1. 식별자 관리 (Identity Management)	-	100%	85%	65%	39%	-24
1.2. 인증 (User Authentication)	-	100%	85%	65%	39%	0
1.3. 위험도 평가 (Risk Assessment)	-	100%	85%	65%	39%	0
1.4. 접근관리 (Risk Assessment)	-	100%	85%	65%	39%	0



5. N²SF vs. SGA ZTA 오버레이 (1/2)

SGA솔루션즈 SGA ZTA 솔루션 도입 시 N²SF 가이드라인 충족 여부 오버레이(overlay)를 통해 관리

✓ N²SF 가이드라인

- 본문에서는 N²SF 적용을 위한 단계별 절차와 보안통제 항목 적용의 예제를 설명
- 부록1에서는 6개 카테고리에 178개 보안통제 항목을 상세히 설명
- 부록2에서는 공공부처가 부록1을 도입/검토 시 8개 정보서비스 모델에 대한 구현 예제를 설명

✓ N²SF vs. SGA ZTA overlay

- N²SF 보안통제 항목 구현 시 SGA ZTA를 기반으로 한 오버레이 접근 전략 마련
- 다양한 보안 솔루션을 ZTA 관점에서 연동하여 178개 보안통제 항목을 만족시킴과 동시에 ZTA 구현 철학이 적용될 수 있도록 함

항목	소항목	보안통제설명	Overlay
1. 최소권한(Least Privilege)	1-1. NNSF-LP-1 : 정보시스템 접근 권한 정의	업무정보(데이터)를 식별하고, 업무정보를 저장하고 있는 정보시스템 접근 권한을 정의한다.	
	1-2. NNSF-LP-2 : 보안통제 권한 제한	보안통제 권한은 정보보안담당관(자) 또는 이에 준하는 관리권한을 부여 받은 인원에게만 부여한다.	
	1-3. NNSF-LP-3 : 보안통제 계정 노출 방지	보안통제 권한 목적으로 사용되는 계정과 이외 기능에 사용되는 계정은 중복 사용하지 않도록 보안통제 권한 계정의 노출을 방지한다.	●
	1-4. NNSF-LP-4 : 원격접속을 통한 관리자 권한 접속제한	기관 네트워크 내부에서 관리자 권한 접속이 제한되는 경우 등 불가피한 상황에서만 한시적으로 기관 네트워크 외부에서의 관리자 권한 접속을 허용하며, 목적이 달성된 경우 외부에서의 관리자 권한 접속을 즉시 차단한다.	●
	1-5. NNSF-LP-5 : 관리자 권한 제한	정보시스템 관리자 권한은 관리자 및 운영자 등 최소한의 인원에게만 부여한다.	●
	1-6. NNSF-LP-6 : 기관 이외 인원의 관리자 권한 제한	기관 구성원 이외 인원에게 관리자 권한은 부여하지 않으며, 다만 정보보안 감사, 사이버보안 실태평가, 사고 조사 및 진단-점검 등에 필요한 경우 외부 인원에게 관리자 권한을 한시적으로 부여할 수 있다.	●
	1-7. NNSF-LP-7: 사용자에게 부여된 관리자 권한 관리	사용자에게 관리자 권한이 부여된 경우 주기적으로 지속 필요 여부를 검토하고 불필요한 경우 권한을 삭제한다.	●
	1-8. NNSF-LP-8 : 코드 실행권한 제한	코드는 필요한 권한으로만 실행되도록 제한하고, 사용자 권한으로 실행되는 코드가 관리자 영역으로 접근되지 않도록 차단한다.	●
	1-9. NNSF-LP-9 : 관리자 권한 실행 로깅 및 감사	관리자 권한 기능 실행 내역은 로깅하고 주기적인 사용 내역 감사를 실시한다.	●

5. N²SF vs. SGA ZTA 오버레이 (2/2)

☞ N²SF vs. SGA ZTA 오버레이 예시

[제1장] 권한					N²SF 우선 검토사항			SGA ZTA Overlay	
대항목	중항목	NNSF ID	소항목	보안통제설명	C 기밀	S 민감	O 공개	제품명	기능
최소권한 Least Privilege (LP)	NNSF-LP-1	NNSF-LP-1	정보시스템 접근 권한 정의	업무정보(데이터)를 식별하고, 업무정보를 저장하고 있는 정보시스템 접근 권한을 정의한다.	●	●			
		NNSF-LP-2	보안통제 권한 제한	보안통제 권한은 정보보안담당관(자) 또는 이에 준하는 관리권한을 부여받은 인원에게만 부여한다.	●	●	●		
		NNSF-LP-3	보안통제 계정 노출 방지	보안통제 권한 목적으로 사용되는 계정과 이외 기능에 사용되는 계정은 중복 사용하지 않도록 보안통제 권한 계정의 노출을 방지한다.	●	●	●		
		NNSF-LP-4	원격접속을 통한 관리자 권한 접속제한	기관 네트워크 내부에서 관리자 권한 접속이 제한되는 경우 등 불가피한 상황에서만 한시적으로 기관 네트워크 외부에서의 관리자 권한 접속을 허용하며, 목적이 달성된 경우 외부에서의 관리자 권한을 즉시 차단한다.	-	●	●		
		NNSF-LP-5	관리자 권한 제한	정보시스템 관리자 권한은 관리자 및 운영자만 부여한다.	●	●			
		NNSF-LP-6	기관 이외 인원의 관리자 권한 제한	기관 구성원 이외 인원에 관리자 권한을 부여하지 않으며, 다만 정보보안 감사, 사이버보안 조사 및 진단·점검 등에 필요한 경우 외부 인원에 관리자 권한을 한시적으로 부여할 수 있다.	●	●	●		
		NNSF-LP-7	사용자에게 부여된 관리자 권한 관리	사용자에게 관리자 권한이 부여된 경우 주기적으로 지속 필요 여부를 검토하고 불필요한 경우 권한을 삭제한다.	-				
		NNSF-LP-8	코드 실행권한 제한	코드는 필요한 권한으로만 실행되도록 제한하고, 사용자 권한으로 실행되는 코드가 관리자 영역으로 접근되지 않도록 차단한다.	●	●	●		
		NNSF-LP-9	관리자 권한 실행 로깅 및 감사	관리자 권한 기능 실행 내역은 로깅하고 주기적인 사용 내역 감사를 실시한다.	●	●	●		
	신원검증 Identity Verification	NNSF-IV-1	관리자 승인	정보시스템 사용자 계정(대민서비스 등 서비스 이용자 계정 제외) 부여를 위한 계정 등록 절차에 정보시스템 관리자(정보화담당관 또는 이에 준하는 관리자)의 승인을 포함한다.	●	●			
		NNSF-IV-2	신원 증거 제출	개인은 신원을 증명할 수 있는 증거를 등록 기관에 제출한다.	●	●			
		NNSF-IV-3	신원 증거 검증	제출된 신원 증거를 검증한다.	●	●			

6. N²SF vs. ZT 2.0 vs. SGA ZTA 오버레이

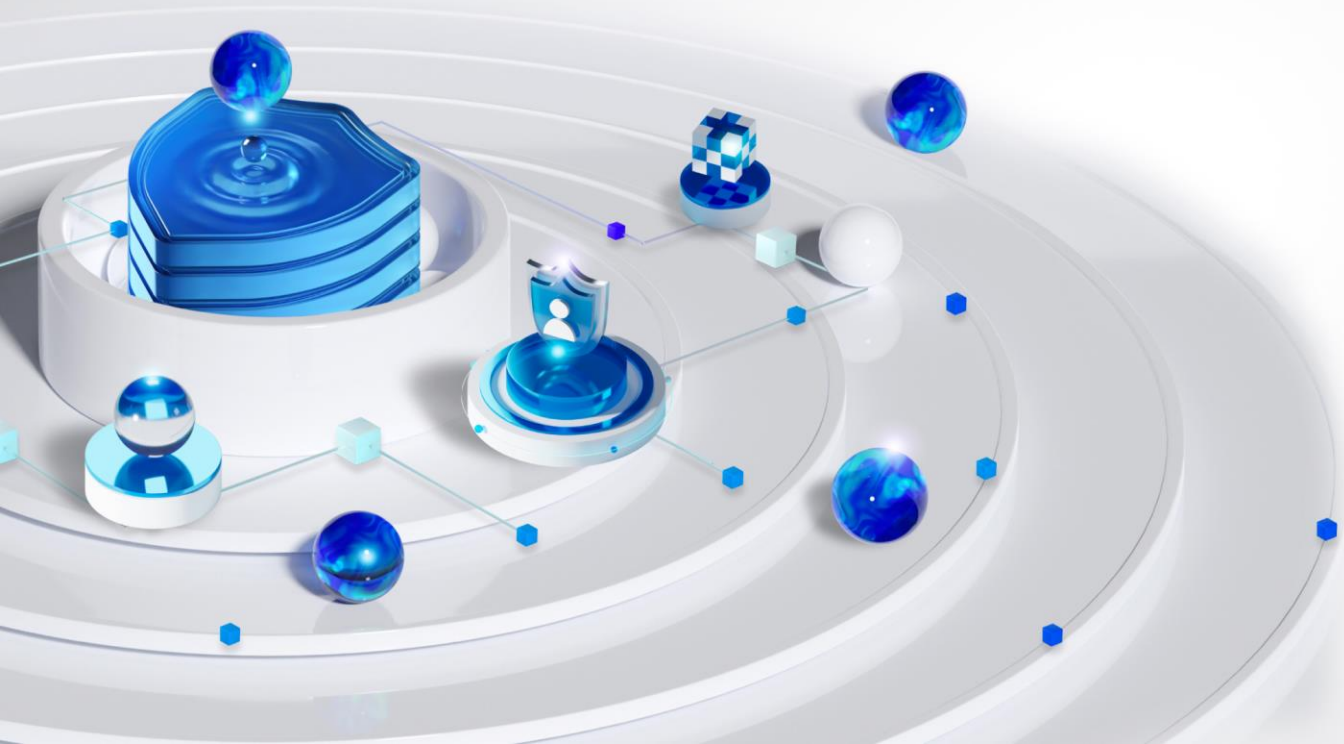
☞ N²SF vs. ZT 2.0 vs. SGA ZTA 오버레이 예시

항목	N²SF	ZT 세부역량	성숙도 기준	SGA ZTA Overlay	
				제품명	기능
보안통제 항목	2-3. NNSF-AC-1 : 계정관리 자동화	1.1.1. 사용자 인벤토리 (User Account inventory)	1 관리 체계 없음		
			2 사용자 계정 목록 수집, 기본적인 사용자 정보관리 및 문서화		
			3 일부 사용자 역할 및 권한을 포함한 상세 인벤토리 관리 및 업데이트		
			4 전체 사용자 ID 통합 관리 시스템 구축(SSO), 비정상적인 사용자 활동 탐지 기능		
			5 인벤토리 통합을 통한 관리 최적화, AI 기반 사용자 행동 관리		
	3-1. NNSF-IM-2 : 사용자 상태 식별	1.1.2. ID연계 및 사용자 자격증명 (Identity and Access Management)	2 사용자 자격 증명에 대한 ID 연계 솔루션 적용		
			3 여러 시스템(내·외부)간 사용자 자격 증명에 대한 연동		
			4 데이터 보호 강화 및 다양한 ID 제공자 통합을 통한 연계연동		
			5 글로벌 수준의 ID연계 정책 및 지속적인 최적화		

III

ISMS-P & ZTA Overlay

1. ISMS-P 인증
2. ISMS-P 인증체계 vs. SGA ZTA Overlay



1. ISMS-P 인증

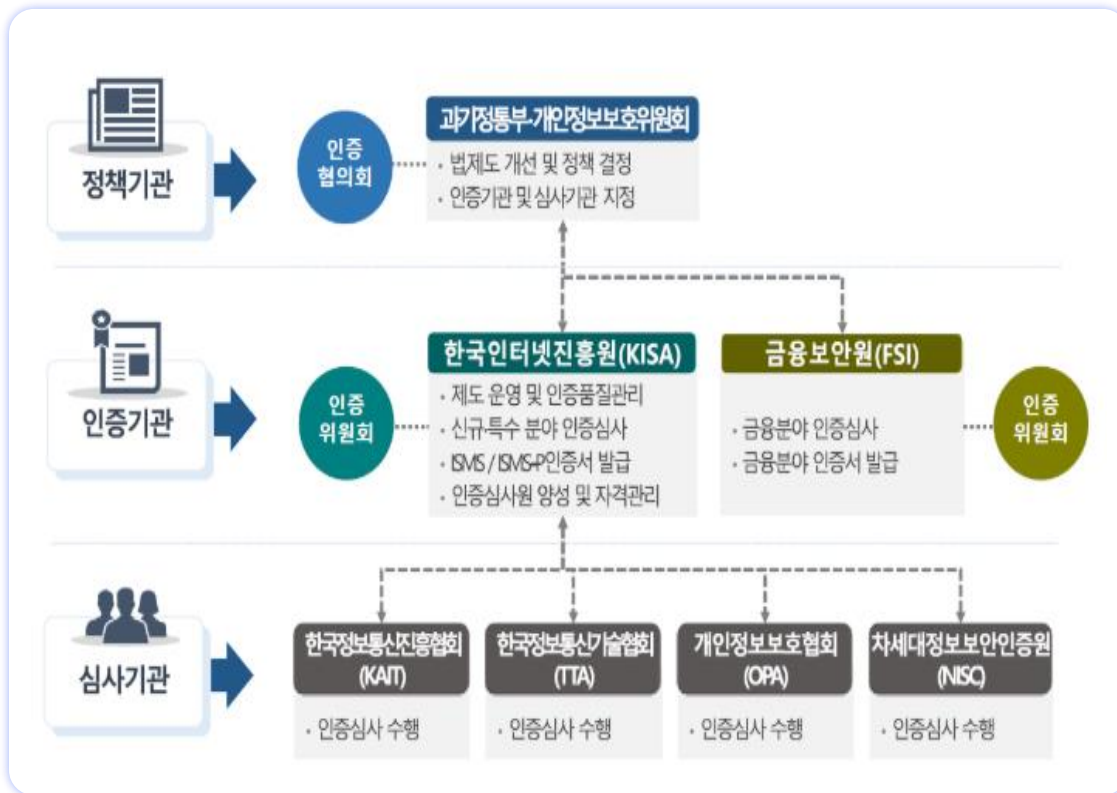
ISMS-P 인증 개요



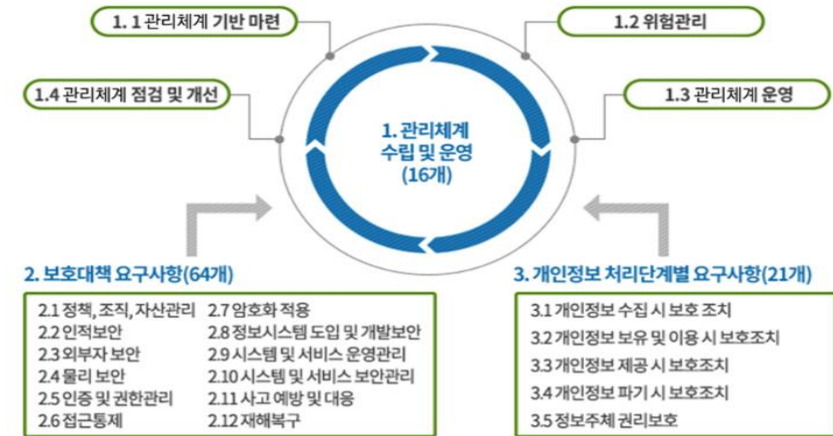
■ 정보보호 및 개인정보보호 관리체계 인증

- 정보보호 및 개인정보보호를 위한 일련의 조치와 활동이 인증기준에 적합함을 인터넷진흥원 또는 인증기관이 증명하는 제도

□ 인증체계



□ 인증기준



구분	통합인증	분야(인증기준 개수)	
ISMS-P	ISMS	1. 관리체계 수립 및 운영 (16)	1.1 관리체계 기반 마련(6) 1.3 관리체계 운영(3) 1.2 위험관리(4) 1.4 관리체계 점검 및 개선(3)
		2. 보호대책 요구사항 (64)	2.1 정책, 조직, 자산 관리(3) 2.3 외부자 보안(4) 2.5 인증 및 권한 관리(6) 2.7 암호화 적용(2) 2.9 시스템 및 서비스 운영관리(7) 2.11 사고 예방 및 대응(5) 2.2 인적보안(6) 2.4 물리보안(7) 2.6 접근통제(7) 2.8 정보시스템 도입 및 개발 보안(6) 2.10 시스템 및 서비스 보안관리(9) 2.12 재해복구(2)
	-	3. 개인정보 처리단계별 요구사항(21)	3.1 개인정보 수집 시 보호조치(7) 3.3 개인정보 제공 시 보호조치(4) 3.5 정보주체 권리보호(3) 3.2 개인정보 보유 및 이용 시 보호조치(5) 3.4 개인정보 파기 시 보호조치(2)

2. ISMS-P 인증체계 vs. SGA ZTA Overlay

ISMS-P 인증 개요

ISMS-P 인증기준 세부점검항목(2023.10.31)

1. 관리체계 수립 및 운영(16개)/세부항목(42개)

분야	항목	상세내용	주요 확인사항
1.1. 관리체계 기반 마련	1.1.1. 경영진의 참여	최고경영자는 정보보호 및 개인정보보호 관리체계의 수립과 운영활동 전반에 경영진의 참여가 이루어질 수 있도록 보고 및 의사결정 체계를 수립하여 운영하여야 한다.	정보보호 및 개인정보보호 관리체계 수립 및 운영활동 전반에 경영진의 참여가 이루어질 수 있도록 보고 및 의사결정 등의 책임과 역할을 문서화하고 있는가?
	1.1.2. 최고책임자의 지정	최고경영자는 정보보호 및 개인정보보호 업무를 총괄하는 정보보호 최고책임자(이하 '최고책임자')를 지정하고, 최고책임자는 정보보호 및 개인정보보호 관리체계의 수립과 운영활동 전반에 경영진의 참여가 이루어질 수 있도록 보고 및 의사결정 체계를 수립하여 운영하여야 한다.	최고경영자는 정보보호 및 개인정보보호 활동에 관한 의사결정에 적극적으로 참여할 수 있는 보고, 검토 및 승인 절차를 수립·이행하고 있는가?
	1.1.3. 조직 구성	최고경영자는 정보보호와 개인정보보호의 효과적 구현을 위한 실무조직, 조직 전반의 정보보호와 개인정보보호 관련 주요 사항을 검토 및 의결할 수 있는 위원회, 전사적 보호활동을 위한 부서별 정보보호와 개인정보보호 담당자로 구성된 협의체를 구성하여 운영하여야 한다.	정보보호 최고책임자 및 개인정보 보호책임자는 예산, 인력 등 자원을 할당할 수 있는 임원급으로 지정하고 있으며 관련 법령에 따른 자격요건을 충족하고 있는가?
	1.1.4. 범위 설정	조직의 핵심 서비스와 개인정보 처리 현황 등을 고려하여 관리체계 범위를 설정하고, 관련된 서비스를 비롯하여 개인정보 처리 업무와 조직, 자산, 물리적 위치 등을 문서화하여야 한다.	조직의 핵심 서비스 및 개인정보 처리에 영향을 줄 수 있는 핵심자산을 포함하도록 관리체계 범위를 설정하고 있는가?

관리체계 수립 및 운영(16개)/
세부항목(42개)

보호대책
요구사항(64개)/세부항목(195개)

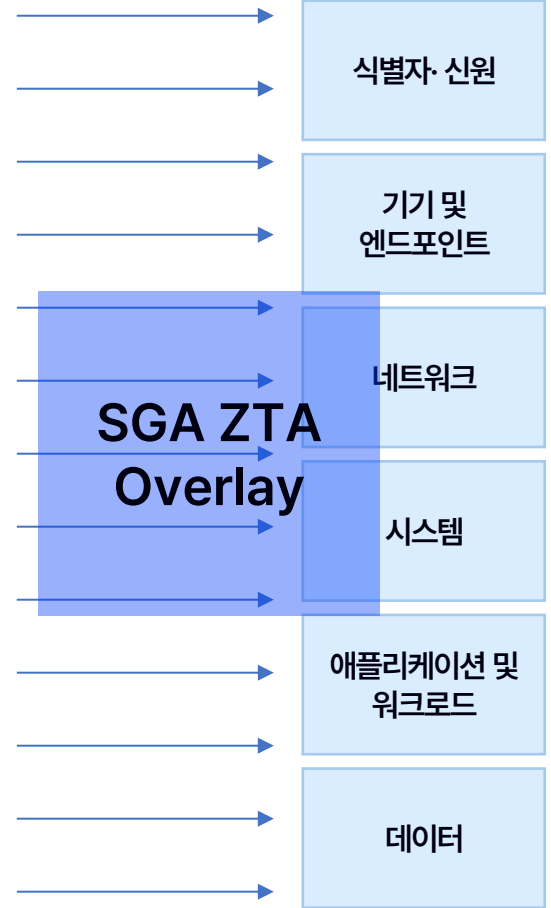
분야	항목	상세내용	주요 확인사항
개인정보 수집 시 보호조치	3.1.1. 개인정보 수집·이용	개인정보는 적법하고 정당하게 수집·이용하여야 하며, 정보주체의 동의를 근거로 수집하는 경우에는 적법한 방법으로 정보주체의 동의를 받아야 한다. 또한 만 14세 미만 아동의 개인정보를 수집하는 경우에는 그 법정대리인의 동의를 받아야 하며 법정대리인이 동의하였는지를 확인하여야 한다.	개인정보를 수집하는 경우 정보주체 동의, 법령상 의무준수, 계약 체결·이행 등 적법 요건에 따라 수집하고 있는가?
개인정보 처리단계별 요구사항(21개)/세부항목(91개)			정보주체에게 개인정보 수집 동의를 받는 경우 동의방법 및 시점은 적절하게 되어 있는가? 정보주체에게 개인정보 수집 동의를 받는 경우 관련 내용을 명확하게 고지하고 법령에서 정한 중요한 내용에 대해 명확히 표시하여 알아보기 쉽게 표시하고 있는가? 만 14세 미만 아동의 개인정보에 대해 수집·이용·제공 등의 동의를 받는 경우 법정대리인에게 필요한 사항에 대하여 고지하고 동의를 받고 있는가? 법정대리인의 동의를 받기 위하여 필요한 최소한의 개인정보만을 수집하고 있으며, 법정대리인이 자격 요건을 갖추고 있는지 확인하는 절차와 방법을 마련하고 있는가? 만 14세 미만의 아동에게 개인정보 처리와 관련한 사항 동의 고지 시 이해하기 쉬운 양식과 명확하고 오해의 소지가 없도록 표현하고 있는가? 정보주체 및 법정대리인에게 동의를 받은 기록을 보관하고 있는가? 정보주체의 동의 없이 처리할 수 있는 개인정보에 대해서는 그 항목과 처리의 법적 근거를 정보주체의 동의를 받아 처리하는 개인정보와 구분하여 개인정보 처리방침에 공개하거나 정보주체에게 알리고 있는가? 정보주체의 동의 없이 개인정보의 추가적인 이용 시 당초 수집 목적과의 관련성, 예측 가능성, 이익 침해 여부, 안전성 확보조치 등의 고려사항에 대한 판단기준을 수립·이행하고, 추가적인 이용이 지속적으로 발생하는 경우 고려사항에 대한 판단기준을 개인정보 처리방침에 공개하고 이를 점검하고 있는가?

개인정보 처리단계별
요구사항(21개)/세부항목(91개)

체크리스트

세부기능
매핑

제로 트러스트
가이드라인 2.0
핵심요소



식별자·신원

기기 및
엔드포인트

네트워크

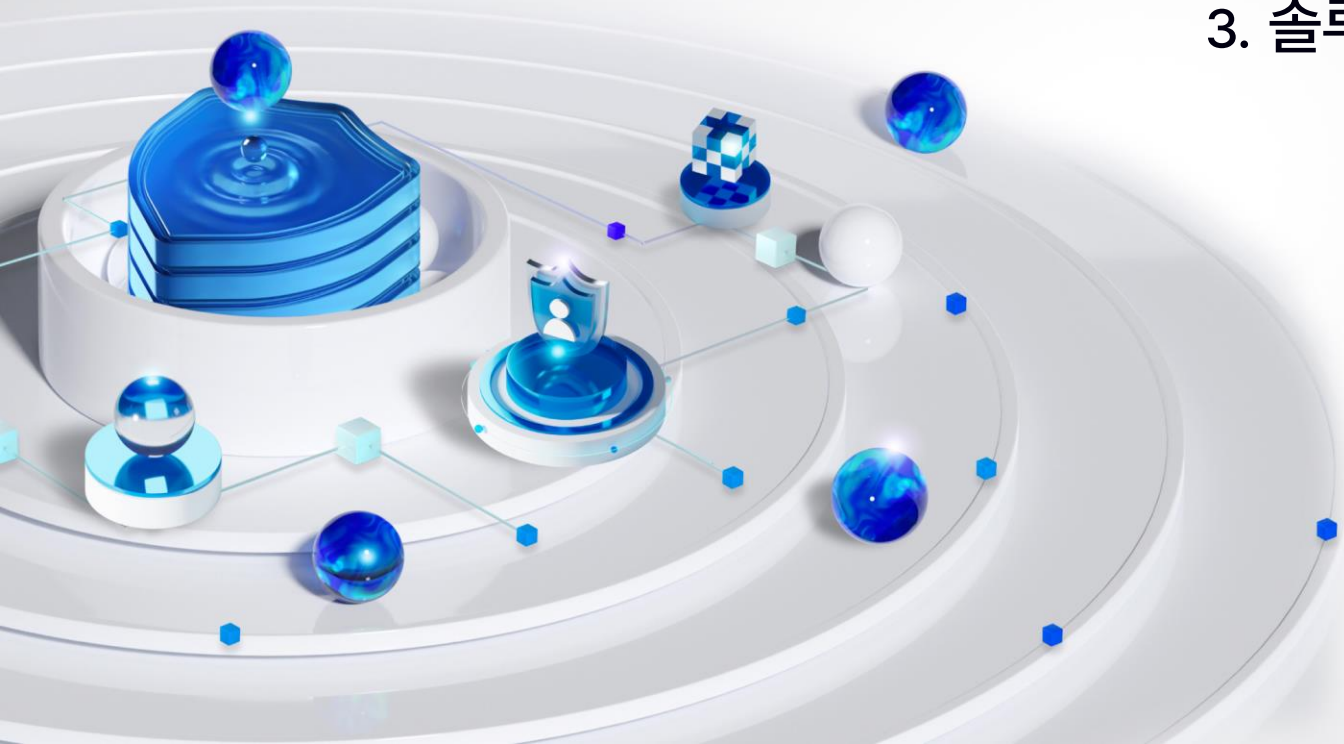
시스템

애플리케이션 및
워크로드

데이터

IV SGA ZTA

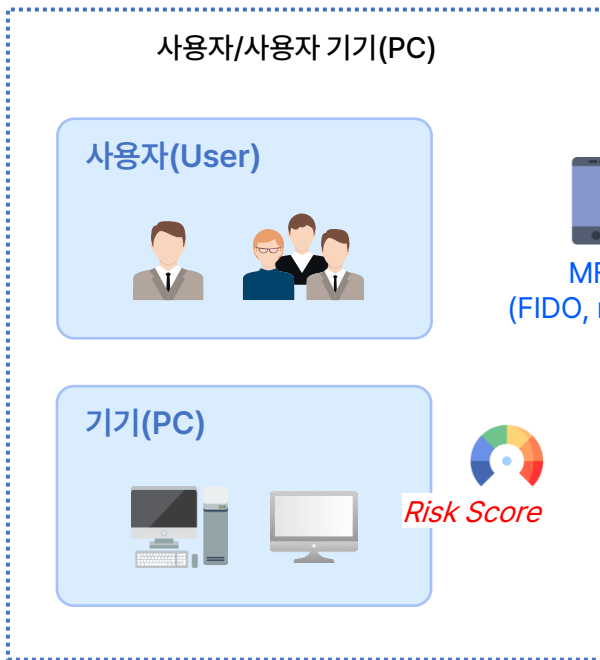
1. 솔루션 개요
2. 솔루션 모델 - ZTA
3. 솔루션 구성



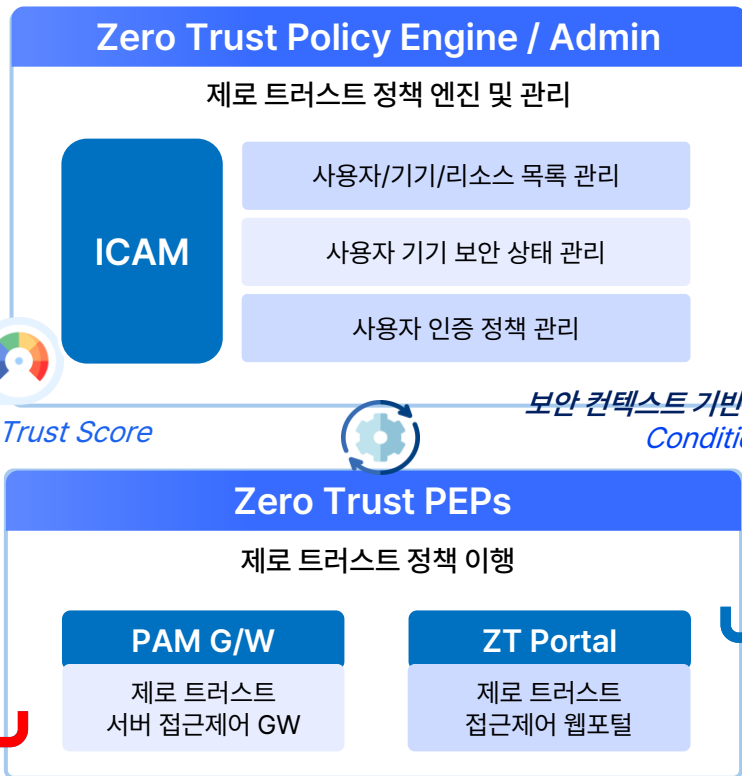
1. 솔루션 개요

Subject~System, PEP, PDP, Enterprise Resource 등 ZTA(Zero Trust Architecture)에 입각한 제로 트러스트 솔루션

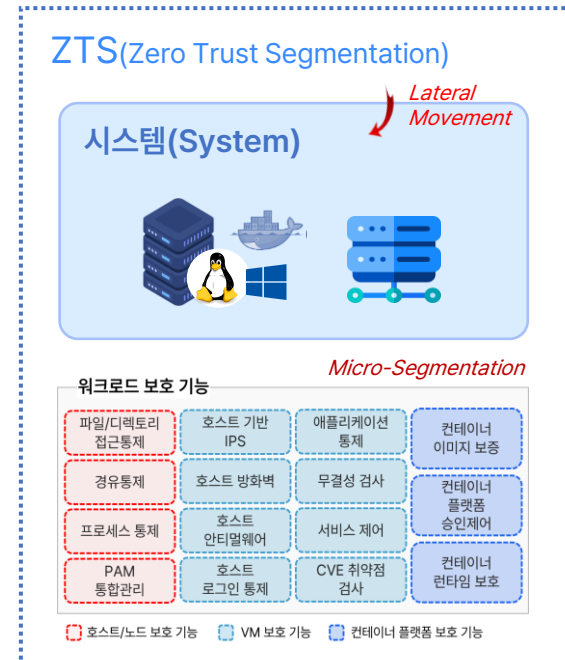
← 엔터프라이즈 리소스 접근 주체 →



- 사용자 보안 컨텍스트(인사정보, 접근시간, 접근위치 등)
- 기기 보안 컨텍스트(기기 식별자, IP, MAC, 취약점 등)



← 접근 대상 리소스 →

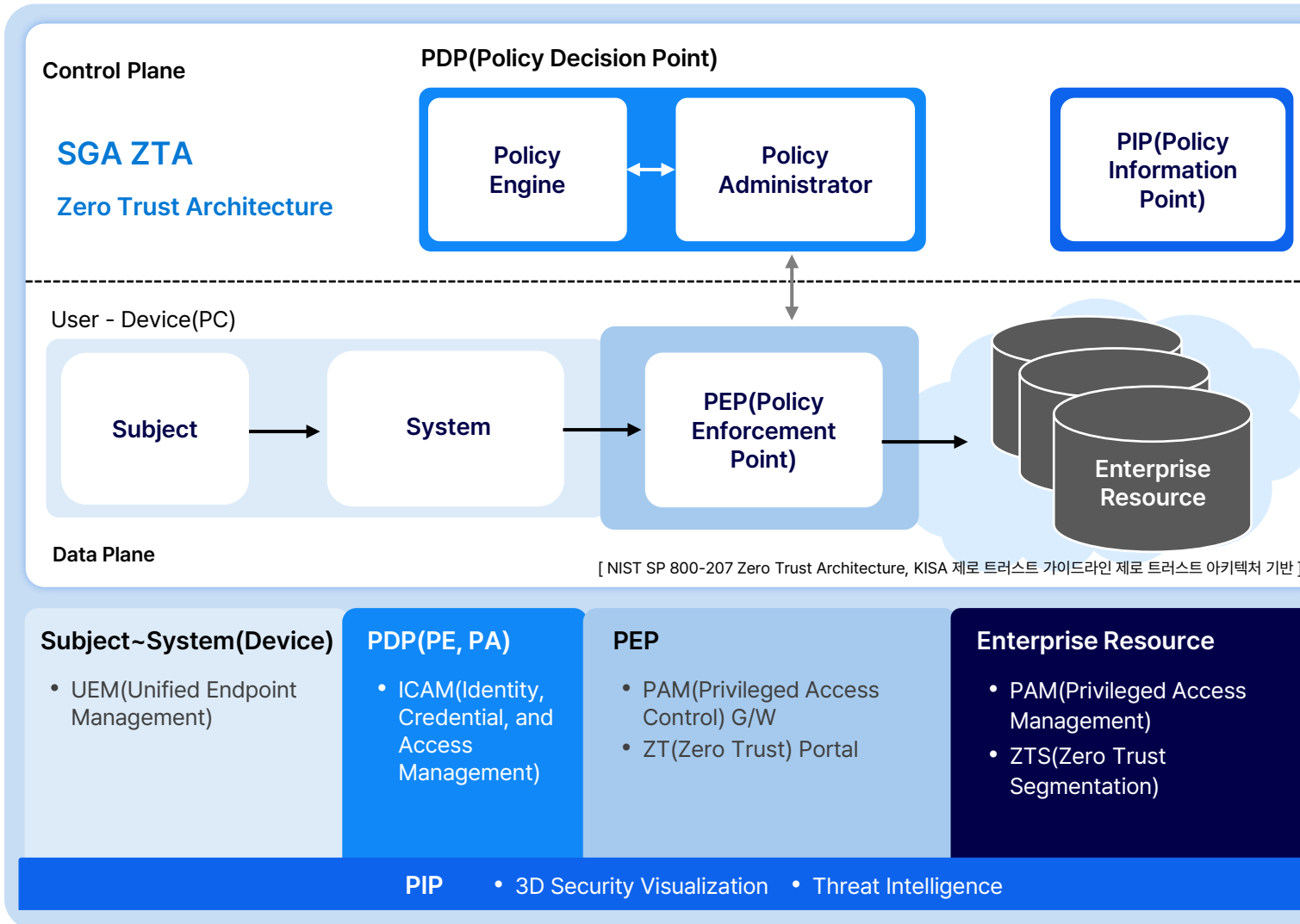


- 엔터프라이즈 리소스 시스템 세부 보호 기능 적용
- 엔터프라이즈 리소스 시스템 간 횡적이동 공격 대응



2. 솔루션 모델 - ZTA

Subject~System, PEP, PDP, Enterprise Resource 등 ZTA(Zero Trust Architecture)에 입각한 제로 트러스트 솔루션 모델



Subject~System

- 업무용PC 엔드포인트 통합 보안관리
- 안티 멀웨어, 패치관리, 보안수준 평가 기반 리스크 스코어링

PDP(정책 결정 지점)

- 신원, 자격증명 및 접근 관리
- 엔터프라이즈 리소스로 접근하는 사용자 및 디바이스 인증, 정책 및 접근관리

PEP(정책 시행 지점)

- 엔터프라이즈 리소스로 접근하는 사용자 및 디바이스 보안 컨텍스트 기반 접근제어

PIP(정책 정보 지점)

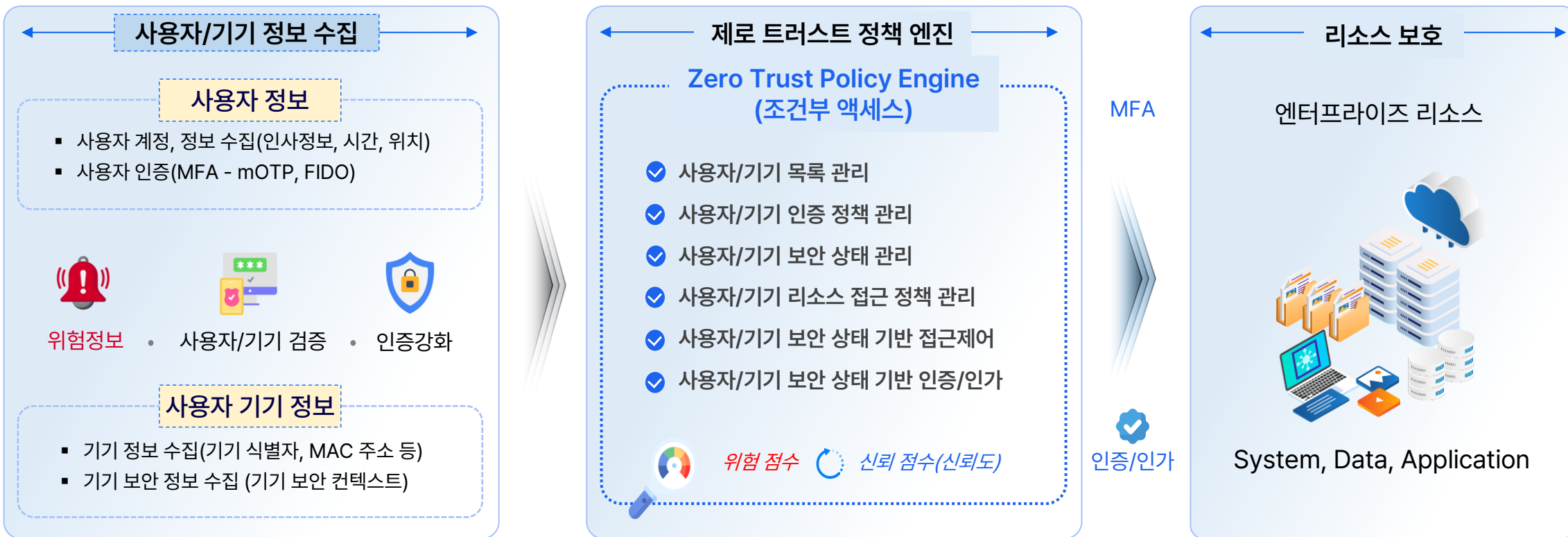
- 정책 결정 서포트(3D 보안 시각화, 위협 인텔리전스)

Enterprise Resource(리소스)

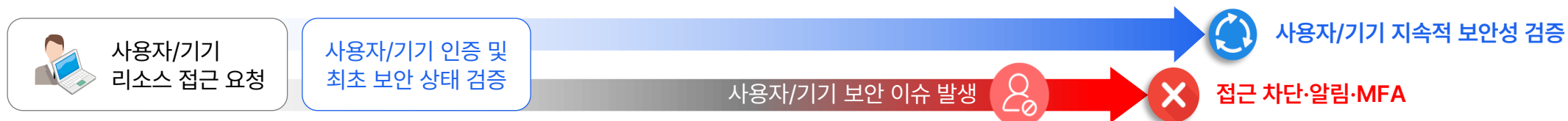
- ERS(Enterprise Resource System) Sector
- Micro-Segmentation 시스템 내부 보호

3. 솔루션 구성 (1/10) – PDP / ICAM

엔터프라이즈 리소스로 접근하는 사용자/사용자 디바이스 인증, 정책 및 접근관리



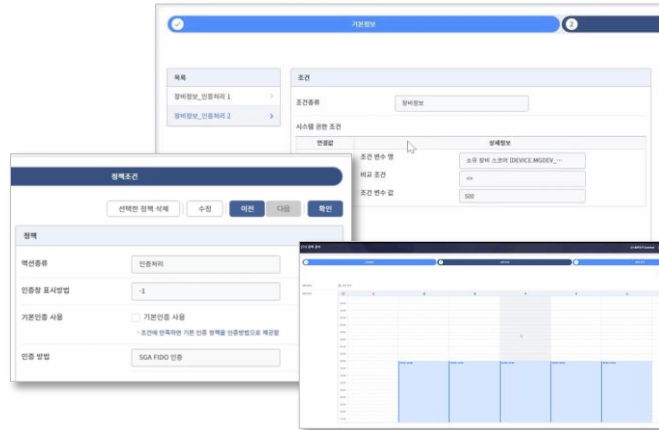
Monitoring(Detection/Response)



Never Trust / Continuous Authorization / Continuous Verification

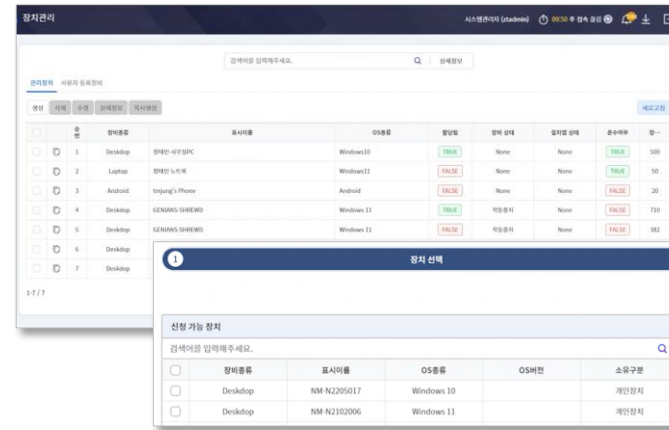
3. 솔루션 구성 (2/10) – PDP / ICAM

실시간 인증/인가, 지속적 유효성 검증



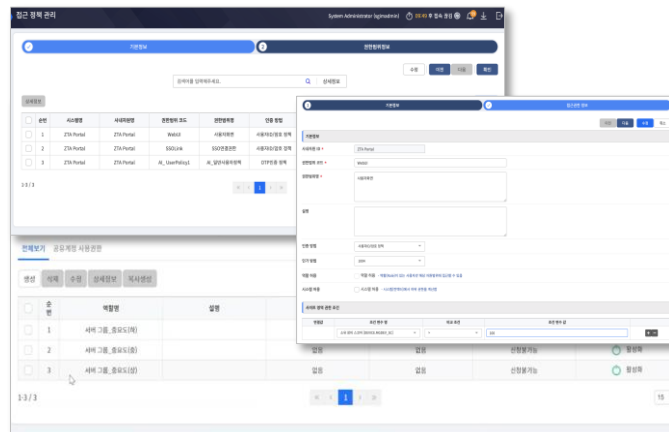
- 전용 API 또는 REST 서비스 호출을 통해 사용자 인증 처리
- 사용자 인증 MFA(mOTP, FIDO)
- 실시간 사용자 인증 및 인가 처리
- 사용자 유효성 검증

사용자 디바이스 보안성 실시간 확인



- 사내 PC 또는 개인장비(BYOD)를 등록하고, 접근이 허용된 장비로만 접근 대상 리소스에 접근 할 수 있도록 정책 수립
- 디바이스 보안 상태를 실시간으로 확인 후, 리소스 접근 허용

접근 대상 리소스별 접근 정책 수립



- 접근 대상 리소스(서버, 웹 업무 서비스 등)
- 접근 대상 리소스 별 중요도 설정(예. 상/중/하 중요도 별 접근 정책 설정)
- 접근 대상 리소스 별 접근 정책 설정(사용자, 디바이스)

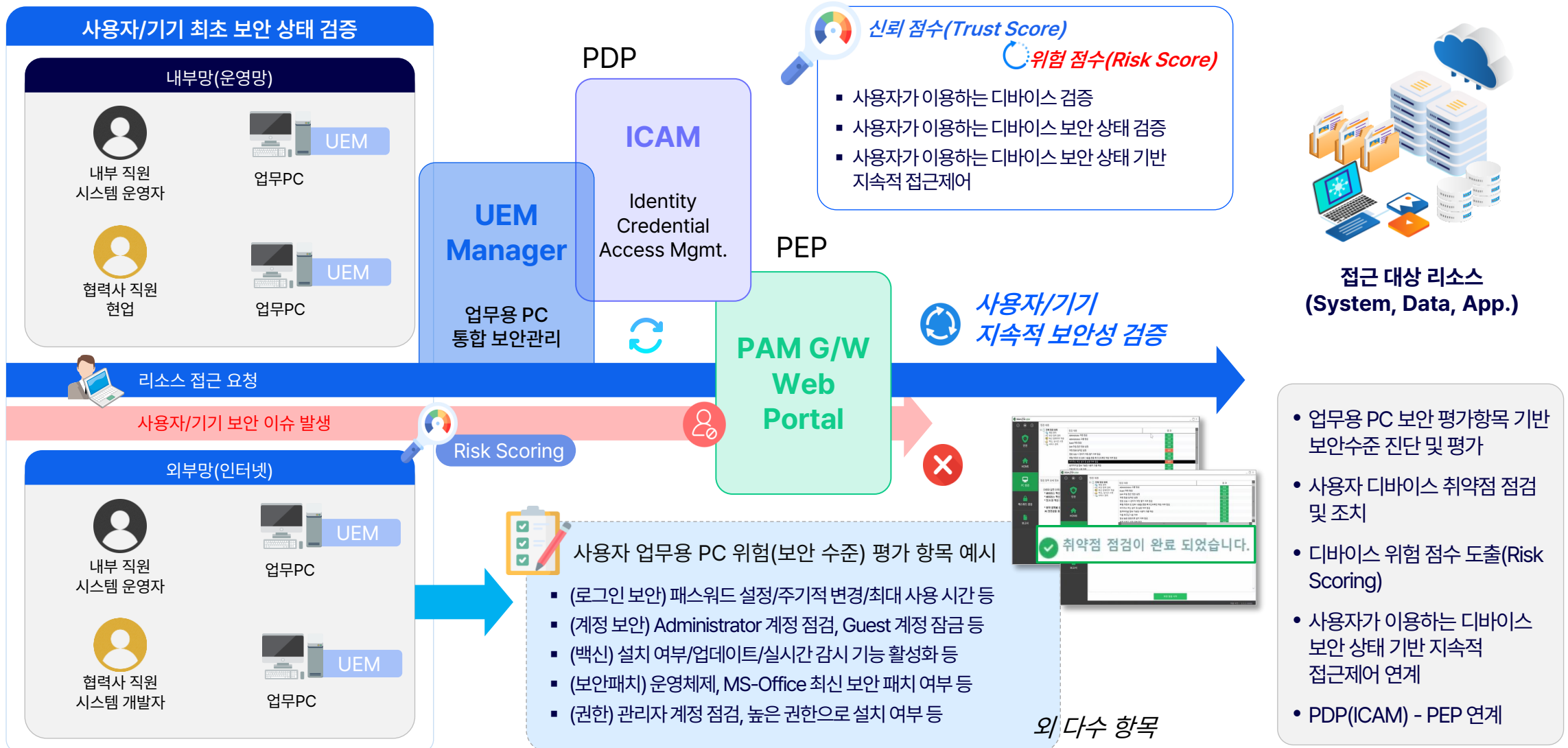
정책 수립 및 배포



- ICAM에서 모든 접근 대상 리소스 및 사용자 관리
- ICAM에서 수립한 정책을 PEP 시스템에 정책 배포
- 사용자 정보, 디바이스 정보, 디바이스 보안 규칙 등 정책 배포/질의

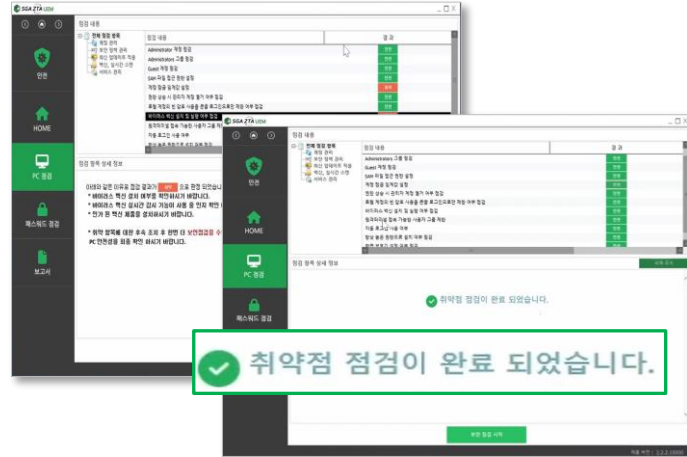
3. 솔루션 구성 (3/10) - 기기(PC) / UEM

엔터프라이즈 리소스로 접근하는 사용자 디바이스 통합 보안관리 및 보안성 검증



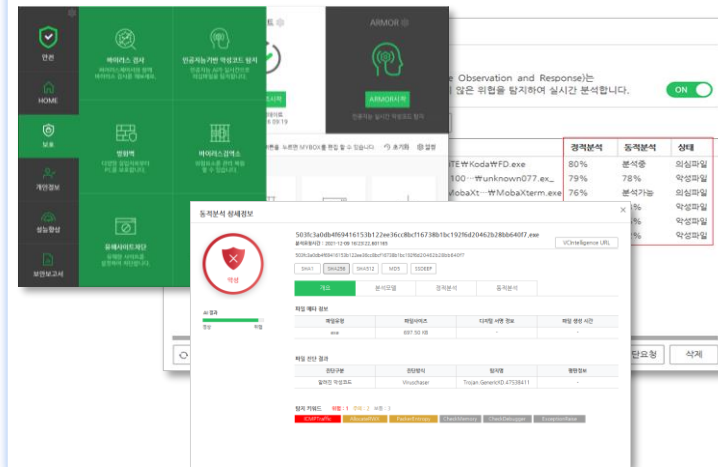
3. 솔루션 구성 (4/10) - 기기(PC) / UEM

기기 보안 상태 평가



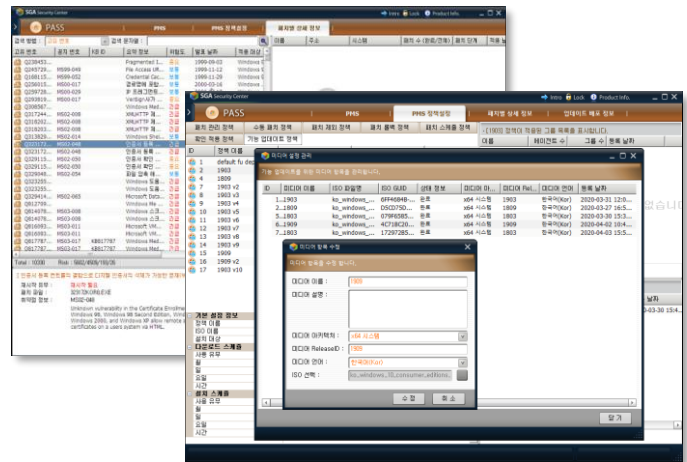
- 업무용 PC 평가 항목 기반 보안 수준 진단 및 평가
- 사용자 기기 취약점 점검 및 자동 조치
- 지속적 기기 위험 점수 도출(Risk Scoring)
- 국내 규정 포함 다수 항목

AI 기반 안티 멀웨어



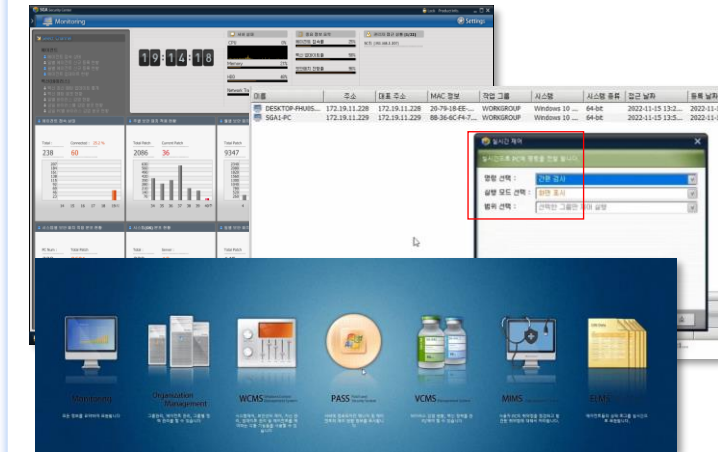
- AI 기반 차세대 백신(NGAV) 기능
- 시그니처 패턴매칭 방식과 AI 머신러닝 엔진 동시 사용
- 랜섬웨어 행위 차단을 위한 폴더 보호 메커니즘, 정책 기반 폴더 접근제어 적용

보안 패치 관리



- P2P 부하분산 기술 기반 패치 관리
- 보안 패치 검색, 적용, 롤백 3단계 관리 방법론 적용
- 패치 별 상세 정보 및 패치 운영, 관리에 대한 보고서 제공

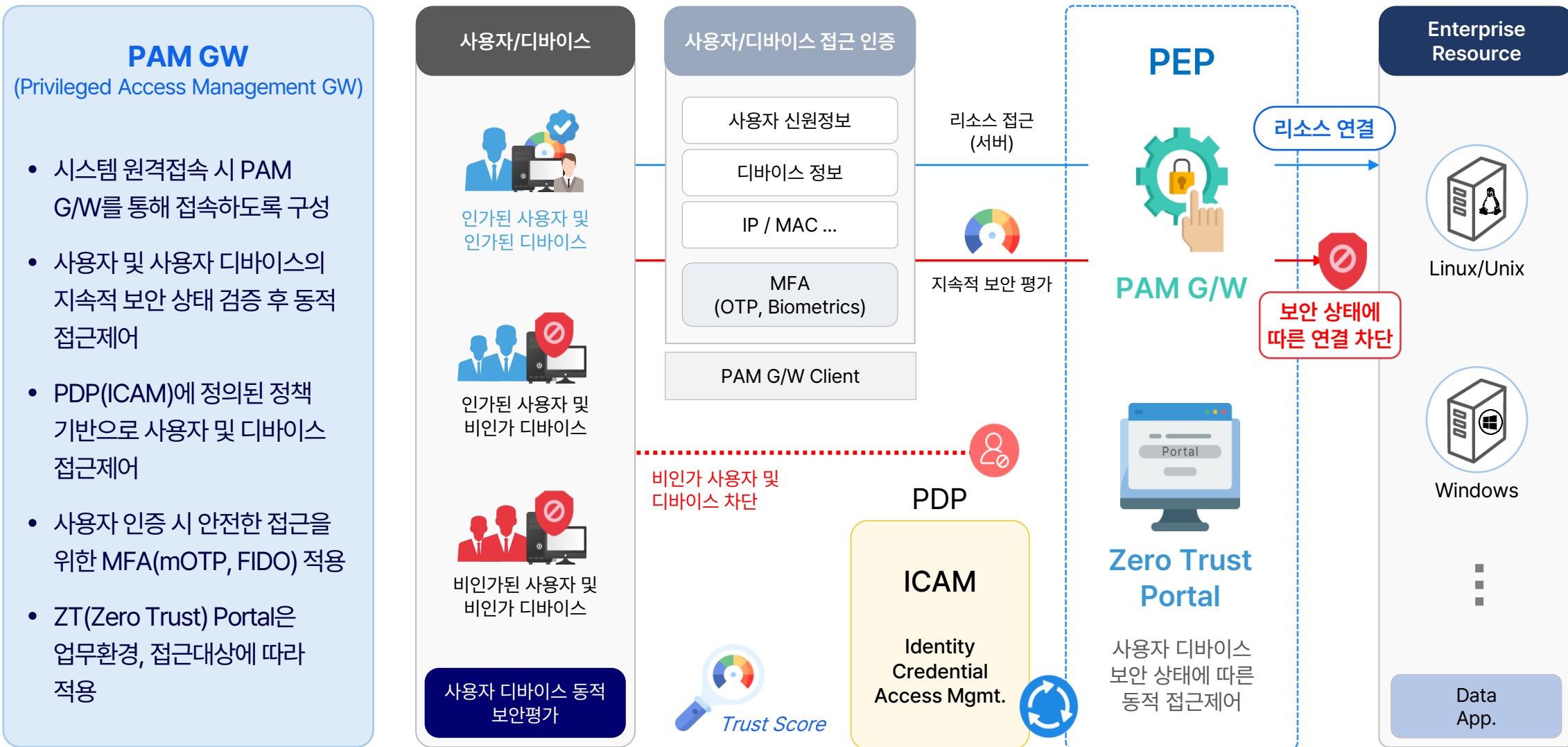
기기 통합 관리/제어



- 백신, 패치, 보안 상태 평가의 그룹, 항목 주기 등 세부 관리 기능
- 검사, 패치, 백신, 랜섬웨어, 상태 평가 항목 등의 상세 정책 수립 및 적용, 제어
- 기기 통합 모니터링, 로그, 실시간 제어

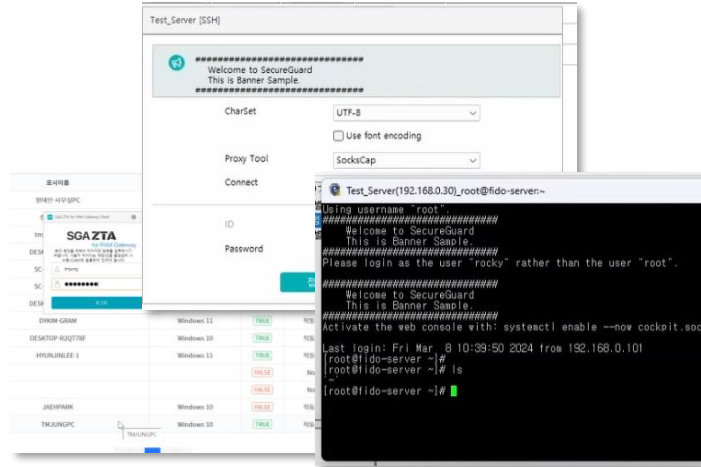
3. 솔루션 구성 (5/10) - PEP / PAM GW

엔터프라이즈 리소스(시스템)로 접근하는 사용자/사용자 디바이스 보안 상태 지속적 검증 및 접근제어



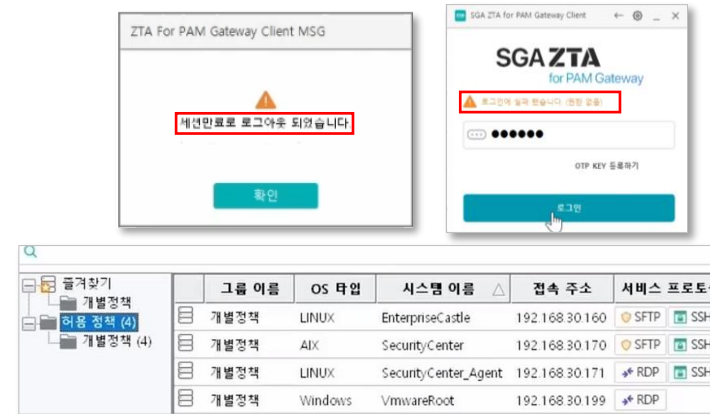
3. 솔루션 구성 (6/10) - PEP / PAM GW

정책 기반 시스템 / 특권 접근제어



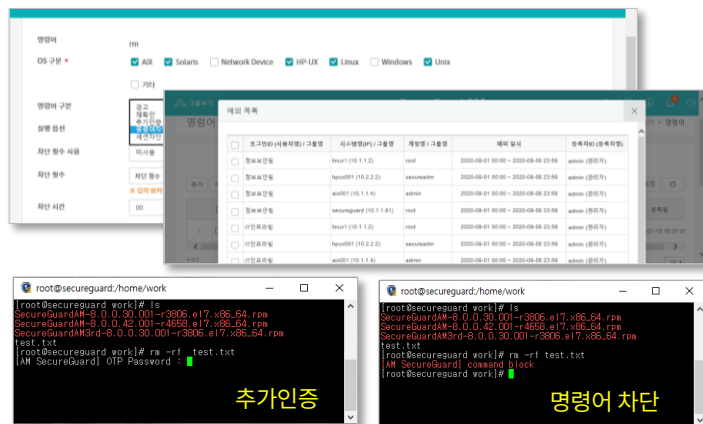
- PDP 정책에 따른 시스템 접근제어
- 시스템/사용자 그룹별, 리소스별 세분화 접근 관리
- 특권 접근 계정, 시스템에 대한 추가 관리 및 최소 권한 원칙 적용

동적 / 세분화 접근제어



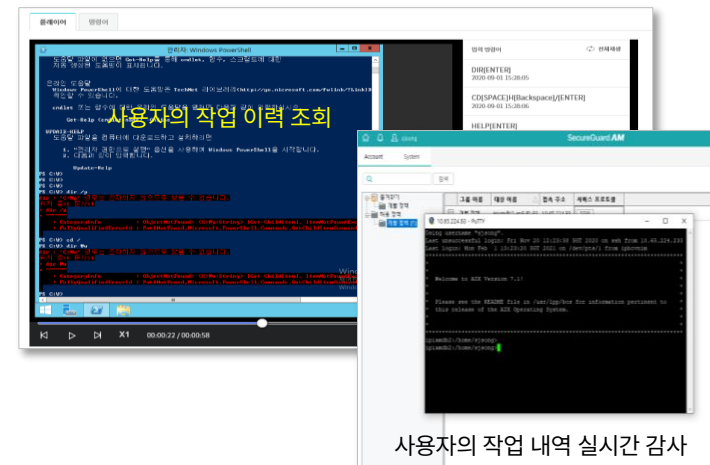
- 접근 시 정책에 따른 추가 인증, 접근 시스템 리스트 변경
- 접근 중 정책 변경 시, 동적 접근차단, 추가 인증, 접근 리소스 변경 등 세분화 접근제어

명령어 제어



- 다양한 명령어 제어 옵션과 상세 제어 정책 수립 제공
- 경고, 재확인, 추가 인증, 세션 차단 등 세부 기능 지정
- 사용자 및 그룹별 예외 정책 설정 기능

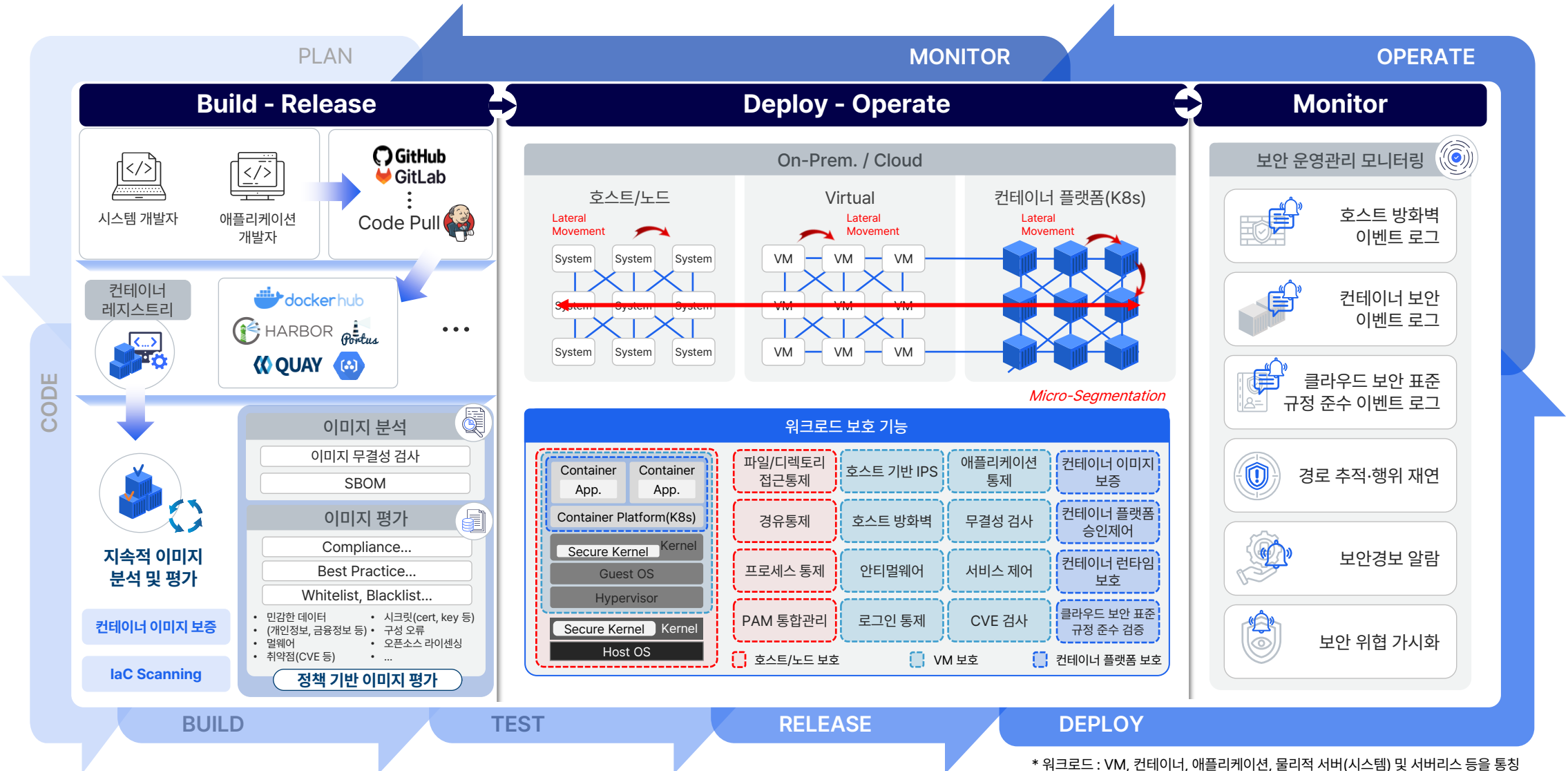
원격 작업 로그 / 실시간 모니터링



- 작업 내역 실시간 저장 및 문제 발생 시 대응
- 다양한 프로토콜 지원 및 실시간 작업 로그, 타임라인 확인
- 리소스 접근 및 작업의 전 과정의 실시간 관리자 모니터링

3. 솔루션 구성 (7/10) - ERS / PAM, ZTS

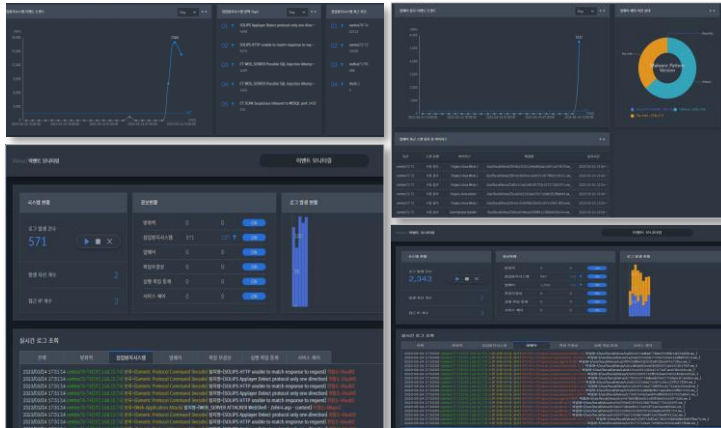
엔터프라이즈 리소스 워크로드 보호 및 DevSecOps, Micro-Segmentation 대응



* 워크로드 : VM, 컨테이너, 애플리케이션, 물리적 서버(시스템) 및 서버리스 등을 통칭

3. 솔루션 구성 (8/10) - ERS / PAM, ZTS

호스트 기반 IPS, 안티멀웨어

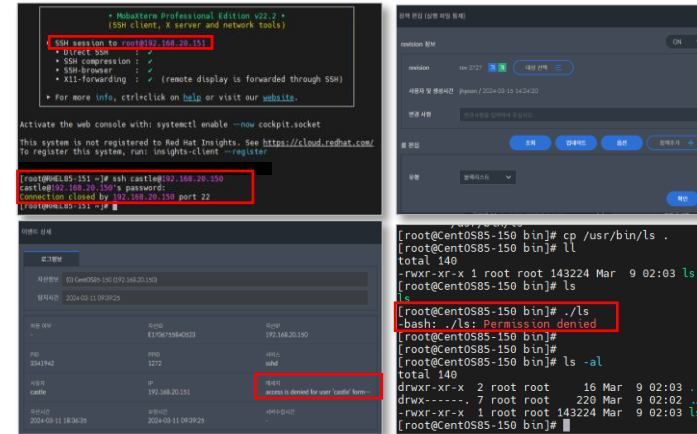


호스트 기반 IPS

호스트 기반 안티멀웨어

- 시그니처 룰셋 기반 침입탐지 및 차단
- DPI 방식 악의적인 패킷 탐지 및 차단
- IPS 패턴 업데이트 및 Snort, PCRE 지원
- 실시간 멀웨어 탐지 및 차단

호스트 서비스 제어, 애플리케이션 통제

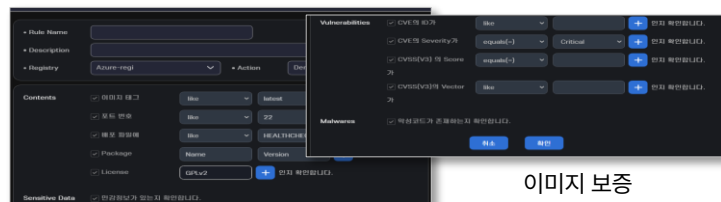


사용자 계정 ssh 서비스 제어

애플리케이션 통제

- sshd, rlogin, vsftpd 등 호스트 서비스 제어
- 사용자/그룹 계정 별 서비스 제어
- IP, Netmask 별 서비스 접근 제어
- 불법적인 프로세스 및 애플리케이션 실행통제

이미지 보증, 컨테이너 플랫폼 승인제어



이미지 보증

```
[root@dev-k8s-master yam1]# kubectl create -f sga-pod.yaml
Error from server: error when creating "sga-pod.yaml": admission webhook "caegis.sgaso1.com" denied the request: Denied by Image Security policy, (kubernetes-admin Cluster ALL0 W RBAC Rule): Image(DIGEST=[sha256:47274bc30468e21217caba33e3244c43c6d5cfaceade76c4b78023f2aca3b2], FULL_TAG=[192.168.20.63:443/tomcat:8.0]) violate Image Security policy, Result to Image Security policy evaluation is [NO PASS]
```

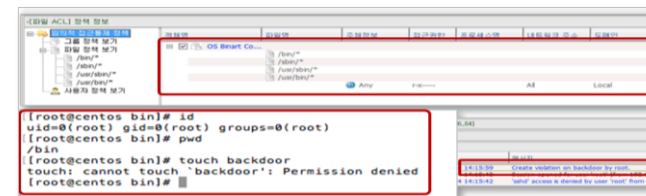
미보증 컨테이너 이미지 배포 제어

```
[root@k8s-master yam1]# kubectl create -f sga-pod.yaml
Error from server: error when creating "sga-pod.yaml": admission webhook "caegis.sgaso1.com" denied the request: Denied by RBAC policy: Operation Deny: Detect rule(Operation: *,Resource: Kind(Kind=Pod, condition=EQUAL IGNORECASE),Scope: Cluster(uid=53596b7c-d66-4a04-ada6-ffa143a9728a, condition=EQUAL)) in RBAC policy
```

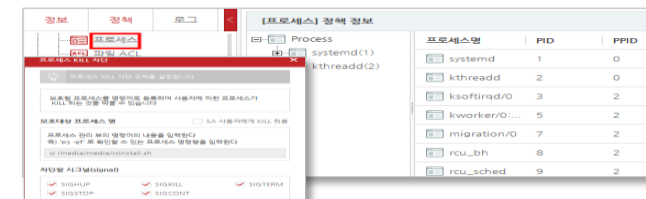
컨테이너 워크로드 실행 제어 - Operation(create)

- 컨테이너 이미지 내 민감한 데이터(개인정보 등), 멀웨어, 취약점, 시크릿, 구성오류, 오픈소스 라이선싱 등 보안 이슈 확인
- 미보증 컨테이너 이미지 배포 제어
- 컨테이너 워크로드 실행제어

(Agent based) PAM



파일/디렉터리 접근 통제



프로세스 통제

- 사용자, 대상 파일/디렉터리 보안 속성 기반 접근통제
- 사용자, 프로세스의 역할, 등급, 그룹 기준 접근 통제
- 보호 대상 프로세스 및 차단 시그널 등록 정책 설정

3. 솔루션 구성 (9/10) - PIP / Visualization

통합 시각화 / 접근 경로 추적



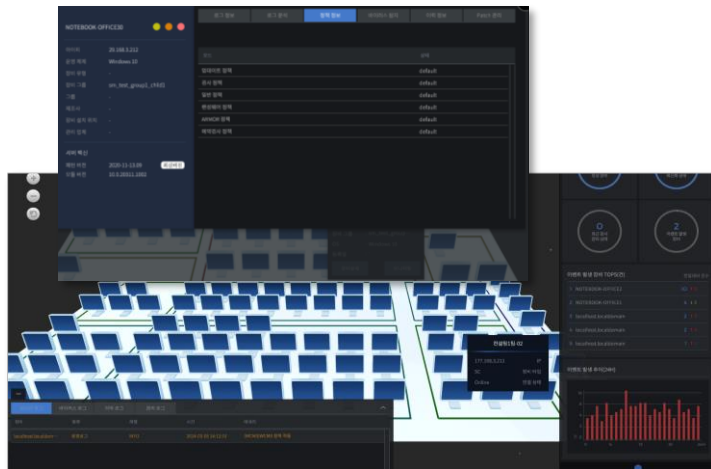
- 모델 내 모든 구성요소 통합 시각화/모니터링
- 접근 그룹(부서)별 관리
- 시스템, 네트워크, 서비스, 엔드포인트 등 영역별 구분
- 실시간 상세 접근 경로 추적 및 분석

통합 시스템 환경 모니터링



- On/Off Prem. 시스템 환경 통합 모니터링
- 시스템별 이벤트 로그, 정책 현황 시각화
- 시스템 자원 사용, 유형, 위치 등 상세 정보
- 실시간, 주의, 경고 등 세분화된 로그 알림

엔드포인트 통합 모니터링



- 백신, 바이러스, 패치 등 보안 상태 관리
- 로그인 실패, 접근 통제, 실시간 바이러스 등 접근제어 로그
- 등급, 보안 상태 별 접근 관련 정책 모니터링
- 그룹, 사용자 매핑

접속 네트워크 및 방화벽 로그



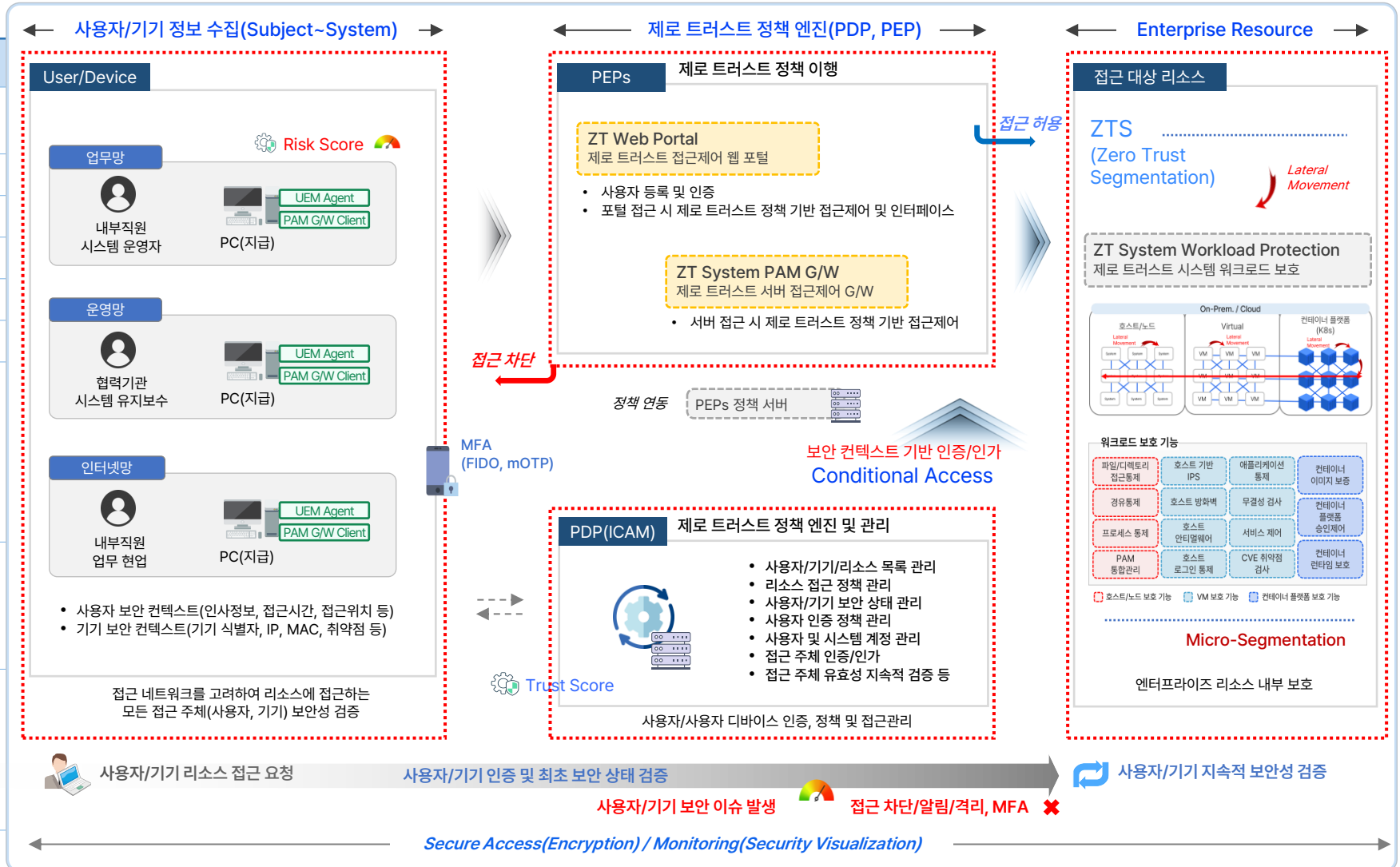
- 네트워크 접근 장비, IP, 그룹, 유형 등 상세 정보
- 네트워크 접근 이벤트, 로그 시각화
- 방화벽 접근 IP 현황, 출발지, 도착지 등 관리
- 접근 장비, 이벤트/경보 발생 등 현황 시각화

3. 솔루션 구성 (10/10) - 구성 및 플로우

접근 주체(사용자, PC)가 엔터프라이즈 리소스로 접근하는 데까지의 Zero Trust Architecture 에 입각한 솔루션 구성 및 플로우

[솔루션 구동 주요 프로세스]

순번	처리 절차 및 행위
1	(통합운영관리시스템->ICAM) 시스템/사용자/계정 정보 연동
2	(Web Portal) 운영관리자/디바이스 사용 신청
3	(ICAM) 운영관리자/디바이스 등록
4	(UEM->ICAM) Risk Score 주기적 전달
5	(ICAM) Risk Score 기반 Trust Score 산출
6	(ICAM->PEP) Trust Score 주기적 전달
7	(PAM GW) 접속 가능 대상 시스템 목록에서 '보호대상 시스템' 조회 * Trust Score 기반 접근 가능 대상 시스템 동적 접근 제어 (주기적으로 전달받은 Trust Score에 따라 '보호대상 시스템'을 목록에서 동적으로 조회)
8	(PAM GW) '보호대상 시스템' 접속 * 주기적으로 사용자의 Trust Score를 전달 받아 '보호대상 시스템' 접속 기준 Trust Score가 미달일 경우 세션 자동 종료
9	(PAM) 시스템 접근통제(파일/디렉토리 접근통제, 명령어 통제, 경유통제 등) (ZTS) 시스템 워크로드 보호 (Host IPS/Firewall/Anti-Malware, 컨테이너 이미지 보증, 컨테이너 플랫폼 승인제어 등)
10	(보안 가시화) 시스템, PC 보안 3D 시각화



감사합니다.

제품문의: jskwak@sgacorp.kr